

Tema 82. Adaptación de aplicaciones y entornos a los requisitos de la normativa de protección de datos según los niveles de seguridad. Herramientas de cifrado y auditoría.

CEF.-

udima
UNIVERSIDAD A DISTANCIA DE MADRID

Abril 2026

Índice

- Adaptación a normativa PD:
  - Principios RGPD.
  - Roles PD: Responsable, Encargado y Delegado de Protección de Datos (DPD).
  - Medidas de adaptación:
    - Deber de información, bases de legitimación y consentimiento expreso.
    - Registro de Actividades del Tratamiento (RAT).
    - Gestión de riesgos y Evaluación de Impacto de Protección de Datos (EIPD).
    - Protección desde el diseño y por defecto. Minimización, seudonimización y hash.
    - Medidas del ENS Anexo II relacionadas con DP.
    - Otras medidas: brechas, portabilidad, supresión. ISO 27701

- Herramientas:
  - AEPD: Facilita, Gestiona, Asesora, Comunica, etc.
  - Cifrado: Guías CCN-STIC 105 (CPSTIC) y 807 (criptología en el ENS).
  - Auditoría: Inés, Amparo, Pilar, etc.

Este tema 82 es un poco mezcla de estos tres temas:

- Tema 27: Normativa de protección de datos personales
- Tema 79: Cifrado. Algoritmos simétricos y asimétricos. La función hash.
- Tema 38: Auditoría informática

OEP 2023

44. ¿Qué técnica utilizaría en un entorno de compartición de datos para garantizar el principio de minimización de datos señalado por el RGPD?

a) Algoritmos de Compresión.
b) Pruebas de conocimiento cero.
c) Indexación de Bases de Datos.
d) Filtrado Cuántico de Relevancia.

OEP 2024 (A2)

12. Señale la opción correcta de acuerdo al Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos):

a) Para realizar un tratamiento de datos personales, no es necesario contar con una base que lo legitime.

b) Para realizar un tratamiento de datos personales, hay que contar con una base que lo legitime. Algunas de las posibles opciones que harían el tratamiento lícito pueden ser, al menos, la información acerca del tratamiento al interesado, el cumplimiento de una obligación legal del responsable, o el cumplimiento de una misión en interés público o en ejercicio de poderes públicos.

c) Para realizar un tratamiento de datos personales, hay que contar con una base que lo legitime. Algunas de las posibles opciones que harían el tratamiento lícito pueden ser, al menos, la información acerca del tratamiento al interesado, el cumplimiento de una obligación legal del responsable, o el cumplimiento de una misión en interés público o en ejercicio de poderes particulares.

d) Para realizar un tratamiento de datos personales, hay que contar con una base que lo legitime. Algunas de las posibles opciones que harían el tratamiento lícito pueden ser, al menos, el consentimiento del interesado, el cumplimiento de una obligación legal del responsable, o el cumplimiento de una misión en interés público o en ejercicio de poderes públicos.

37. ¿Cuál es la herramienta del CCN para la gobernanza de la ciberseguridad, que permite evaluar regularmente el estado de la seguridad de los sistemas TIC de las entidades, organismos y organizaciones?

a) ATENEA.

b) CLARA.

c) INES.

d) CARLA.

89. En criptografía, ¿qué es el "hashing"?

a) Un proceso para convertir datos en una cadena de longitud fija.

b) Un método para encriptar datos.

c) Un protocolo de comunicación seguro.

d) Un tipo de ataque de red.

Preguntas años anteriores…

OEP 2022

Ordinaria:

22. En el entorno de la protección de datos, se emplean las técnicas de Pruebas de Conocimiento Cero o Nulo (ZKP, zero knowledge proof) con el fin de:

a) Acceder a datos personales sin necesidad de autenticarse.

b) Minimizar y limitar el acceso a los datos personales.

c) Intercambiar metadatos con un tercero confiable, en una aplicación Internet.

d) Permitir el acceso a las aplicaciones a personas sin conocimientos previos.

Extraordinaria:

8. ¿Cuál de las herramientas de la AEPD (Agencia Española de Protección de Datos) está diseñada para el análisis de necesidad de una Evaluación de Impacto en Protección de Datos?:

a) Facilita RGPD.

b) Comunica-Brecha RGPD.

c) Gestiona RGPD.

d) Evalua-Riesgo RGPD.

102. ¿Cuál es el plazo que establece el RGPD (Reglamento General de Protección de Datos), (UE) 2016/679, como obligación para la realización de una auditoría de protección de datos?:

a) Cada 2 años de forma general, al realizar una evaluación de conformidad.

b) Cada año para los sistemas de alto riesgo que requieran EIPD (Evaluación de Impacto de Protección de Datos), cada dos años para el resto.

c) No establece un plazo. La Autoridad de Control determina cuándo realizar auditorías de protección de datos.

d) Cada vez que se realice un cambio significativo en el perfil de riesgo del sistema.

OEP 2020

Extraordinaria:

52. ¿Cuál de las siguientes respuestas NO es obligatoria para adaptarse al RGPD?:

a) Obligación de informar al ciudadano sobre el tratamiento de los datos personales.

b) Designar un Delegado de Protección de Datos en los supuestos contemplados en la normativa de protección de datos.

c) Mantener un registro de actividades de tratamiento en el que se detalle quien trata los datos, finalidad y base jurídica.

d) Que los administradores de las BB.DD estén certificados por la AEPD.

30. Señale cuál de las siguientes circunstancias NO es una base que legitime el tratamiento de datos personales, de acuerdo con lo dispuesto en el artículo 6 del Reglamento (UE) 2016/679 del Parlamento Europeo del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos):

a) El tratamiento es necesario para el cumplimiento de una obligación legal aplicable al responsable del tratamiento.

b) El tratamiento es necesario para proteger intereses vitales del interesado o de otra persona física.

c) El tratamiento es necesario para la ejecución de un contrato en el que el interesado es parte o para la aplicación a petición de este de medidas precontractuales.

d) El tratamiento es necesario para ofrecer al interesado servicios públicos o privados en términos de calidad y eficiencia.

OEP 2019

Libre. Ordinaria:

65. En relación con las evaluaciones de impacto de protección de datos (EIPD), señale la opción INCORRECTA:

a. La EIPD es obligatoria cuando las operaciones de tratamiento entrañen un alto riesgo para los derechos y libertades de las personas físicas.
b. La EIPD es obligatoria para todos los tratamientos de datos de las administraciones públicas.
c. El resultado de la evaluación debe tenerse en cuenta para determinar las medidas que mitiguen los riesgos, de forma que el tratamiento mantenga las garantías de protección de datos.
d. Si no es posible mitigar el riesgo con medidas técnicas u organizativas, debe plantearse una consulta a la Agencia Española de Protección de Datos.

Interna. Ordinaria:

19. El tratamiento de datos personales de manera tal, que ya no puedan atribuirse a un interesado sin utilizar información adicional, siempre que dicha información adicional figure por separado y esté sujeta a medidas técnicas y organizativas destinadas a garantizar que los datos personales no se atribuyan a una persona física identificada o identificable, se denomina:

a. Segregación.
b. Seudonimización.
c. Anonimización.
d. Desintegración.

20. Según la normativa vigente de protección de datos, el principio de minimización implica que los datos personales:

a. Serán adecuados, pertinentes y limitados a lo necesario en relación con los fines para los que son tratados.
b. Serán exactos y, si fuera necesario, actualizados, suprimidos o rectificados sin dilación.
c. Serán adecuados, pertinentes y no excesivos.
d. Se mantendrán anonimizados.

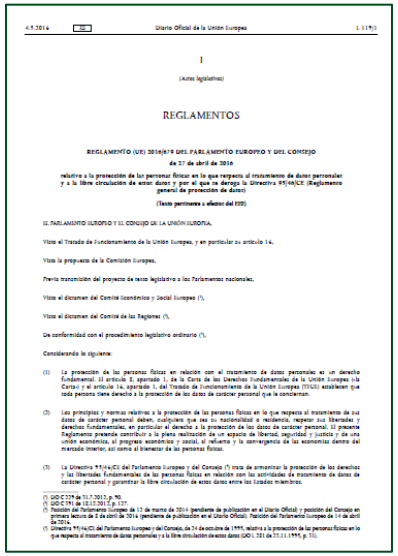
Marco normativo

- Reglamento europeo 2016/679 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos.

- Ley Orgánica 3/2018, de Protección de Datos Personales y garantía de los derechos digitales.

- Real Decreto 311/2022, por el que se regula el Esquema Nacional de Seguridad.

RGPD



4.5.2016 — Diario Oficial de la Unión Europea — L 119/1

I

(Actos legislativos)

REGLAMENTOS

REGLAMENTO (UE) 2016/679 DEL PARLAMENTO EUROPEO Y DEL CONSEJO

de 27 de abril de 2016

relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos)

(Texto pertinente a efectos del EEE)

EL PARLAMENTO EUROPEO Y EL CONSEJO DE LA UNIÓN EUROPEA,

Vista el Tratado de Funcionamiento de la Unión Europea, y en particular su artículo 16,

Vista la propuesta de la Comisión Europea,

Previa transmisión del proyecto de acto legislativo a los Parlamentos nacionales,

Vista el dictamen del Comité Económico y Social Europeo (1),

Vista el dictamen del Comité de las Regiones (2),

De conformidad con el procedimiento legislativo ordinario (3),

Considerando lo siguiente:

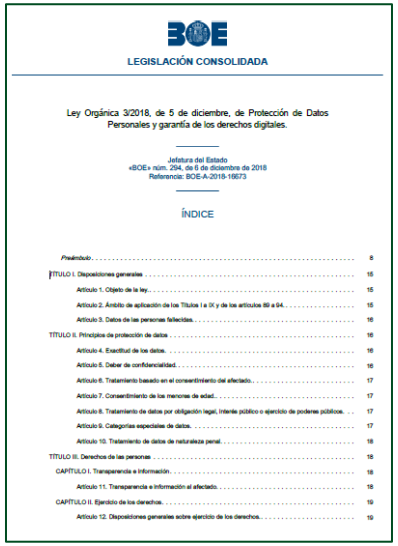
(1) La protección de las personas físicas en relación con el tratamiento de datos personales es un derecho fundamental. El artículo 8, apartado 1, de la Carta de los Derechos Fundamentales de la Unión Europea («la Carta») y el artículo 16, apartado 1, del Tratado de Funcionamiento de la Unión Europea (TFUE) establecen que toda persona tiene derecho a la protección de los datos de carácter personal que le conciernan.

(2) Los principios y normas relativos a la protección de las personas físicas en lo que respecta al tratamiento de sus datos de carácter personal deben, cualquiera que sea su nacionalidad o residencia, respetar sus libertades y derechos fundamentales, en particular el derecho a la protección de los datos de carácter personal. El presente Reglamento pretende contribuir a la plena realización de un espacio de libertad, seguridad y justicia y de una unión económica, al progreso económico y social, al refuerzo y la convergencia de las economías dentro del mercado interior, así como al bienestar de las personas físicas.

(3) La Directiva 95/46/CE del Parlamento Europeo y del Consejo (4) trata de armonizar la protección de los derechos y las libertades fundamentales de las personas físicas en relación con las actividades de tratamiento de datos de carácter personal y garantizar la libre circulación de estos datos entre los Estados miembros.

(1) DOC 229 de 31.7.2012, p. 90.
(2) DOC 391 de 18.12.2012, p. 127.
(3) Posición del Parlamento Europeo de 12 de marzo de 2014 (pendiente de publicación en el Diario Oficial) y posición del Consejo en primera lectura de 8 de abril de 2016 (pendiente de publicación en el Diario Oficial). Posición del Parlamento Europeo de 14 de abril de 2016.
(4) Directiva 95/46/CE del Parlamento Europeo y del Consejo, de 24 de octubre de 1995, relativa a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (DO L 281 de 23.11.1995, p. 31).

LOPD



BOE

LEGISLACIÓN CONSOLIDADA

Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales.

Jefatura del Estado
«BOE» núm. 294, de 6 de diciembre de 2018
Referencia: BOE-A-2018-16673

ÍNDICE

Preámbulo 6
TÍTULO I. Disposiciones generales 15
Artículo 1. Objeto de la ley. 15
Artículo 2. Ámbito de aplicación de los Títulos I a IX y de los artículos 89 a 94. 15
Artículo 3. Datos de las personas fallecidas. 16
TÍTULO II. Principios de protección de datos 16
Artículo 4. Exactitud de los datos. 16
Artículo 5. Deber de confidencialidad. 16
Artículo 6. Tratamiento basado en el consentimiento del afectado. 17
Artículo 7. Consentimiento de los menores de edad. 17
Artículo 8. Tratamiento de datos por obligación legal, interés público o ejercicio de poderes públicos. 17
Artículo 9. Categorías especiales de datos. 17
Artículo 10. Tratamiento de datos de naturaleza penal. 18
TÍTULO III. Derechos de las personas 18
CAPÍTULO I. Transparencia e información. 18
Artículo 11. Transparencia e información al afectado. 18
CAPÍTULO II. Ejercicio de los derechos. 19
Artículo 12. Disposiciones generales sobre ejercicio de los derechos. 19

ENS



BOE

LEGISLACIÓN CONSOLIDADA

Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad.

ÍNDICE

- Anexo II
- Auditoría

Principios RGPD

Del artículo 5 del RGPD se pueden extraer los siguientes **principios**:

- Principio de licitud, transparencia y lealtad en el tratamiento de los datos.
- Principio de limitación de la finalidad, que determina que los datos deben ser tratados con una o varias finalidades determinadas, explícitas y legítimas, prohibiendo tratamientos posteriores incompatibles con esos fines.
- Principio de minimización de datos, que sean adecuados, pertinentes y limitados a lo necesario en relación con las finalidades.
- Principio de exactitud, de forma que los datos estén actualizados y se supriman o modifiquen en cuanto sean inexactos.
- Principio de limitación del plazo de conservación, por el que los datos deben borrarse, bloquearse o anonimizarse una vez la finalidad ha sido alcanzada.
- Principio de seguridad por el que responsables y encargados deben realizar un análisis de riesgos que les permita determinar las medidas técnicas y organizativas adecuadas para asegurar la integridad y confidencialidad.

Principio de responsabilidad (pro)activa

- Este principio se refiere a que el responsable del tratamiento debe aplicar las medidas técnicas y organizativas apropiadas para garantizar y poder demostrar que el tratamiento es conforme con el Reglamento.

- En el RGPD, no se especifica un conjunto concreto de medidas (como sí sucedía en el marco normativo anterior) sino que el responsable tiene la "libertad" y la "responsabilidad" de aplicar las medidas que consideren adecuadas y suficientes.

- En síntesis, este principio exige una actitud consciente, diligente y proactiva por parte de las organizaciones frente a todos los tratamientos de datos personales que lleven a cabo.



El marco normativo de la protección de datos personales establece 3 figuras fundamentales:

- **Responsable** del tratamiento: persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros (corresponsables), determina las finalidades y medios del tratamiento.

- **Encargado** del tratamiento: persona física o jurídica, autoridad pública, servicio u otro organismo que trata los datos personales por cuenta del responsable del tratamiento.

- **Delegado** de Protección de Datos (DPD): supervisor, asesor, interlocutor, cooperador, punto de contacto.







Responsable del tratamiento

Las principales obligaciones del responsable son:

- Registro e inventario de las actividades del tratamiento (RAT).
- Designación, en su caso, de un Delegado de Protección de Datos (DPD).
- Análisis del riesgo del tratamiento y, en su caso, evaluación de impacto para la protección de datos (EIPD) y consulta previa a la Autoridad de Control.
- Protección de datos desde el diseño y por defecto.
- Notificación de brechas de datos a la Autoridad de Control.
- Comunicación de brechas de datos a los interesados.
- Elaboración de códigos de conducta.
- Establecimiento de garantías para las transferencias de datos personales a terceros países (fuera UE) u organizaciones internacionales.

Encargado del tratamiento

En base al artículo 28 del RGPD, las principales obligaciones del encargado son:

- Tratar los datos personales únicamente siguiendo las instrucciones documentadas del responsable.
- Garantizar que las personas autorizadas para tratar datos personales se hayan comprometido a respetar la confidencialidad.
- Tomar todas las medidas necesarias de acuerdo con el artículo 32 de seguridad del tratamiento.
- Asistir al responsable para que pueda cumplir con su obligación de responder a las solicitudes que tengan por objeto el ejercicio de los derechos de los interesados.
- A elección del responsable, suprimir o devolver los datos personales una vez finalice la prestación de los servicios de tratamiento, y suprimir las copias existentes a menos que se requiera la conservación de los datos.
- Poner a disposición del responsable toda la información necesaria para demostrar el cumplimiento de sus obligaciones establecidas.

Seguridad del tratamiento (artículo 32)

- Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:
  - la seudonimización y el cifrado de datos personales.
  - la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento.
  - la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico.
  - un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.
- Las relaciones entre el responsable y encargado deben formalizarse con contrato o acto jurídico que les vincule.

Funciones principales:

- Informar y asesorar al responsable, al encargado y a los empleados que se ocupen del tratamiento de sus obligaciones en materia de protección de datos personales. Emitir recomendaciones.

- Supervisar el cumplimiento normativo, incluida la asignación de responsabilidades, la concienciación y formación del personal, y en su caso las posibles auditorías.
  - Las auditorías de protección de datos no son obligatorias, pero sí puede ser una medida de seguridad disponible a criterio del responsable.

- No tomar decisiones, ni hacer análisis de riesgos, ni EIPD.
  - Por ejemplo, el régimen sancionador de la LOPD no aplica al DPD.

- Cooperar y actuar como interlocutor del responsable o encargado ante la AEPD.

- Punto de contacto para los interesados. Atender las reclamaciones. 2 meses para contestar si viene del afectado, 1 mes si viene de la AEPD.

Delegado de Protección de Datos (DPD)

- Perfil **obligatorio** sólo en los siguientes casos (voluntario para el resto de las entidades):

  - RGPD:
    - Autoridades y organismos públicos.
    - Tratamientos que requieran observación habitual y sistemática a gran escala.
    - Tratamientos a gran escala de datos sensibles (de origen étnico o racial, opiniones políticas, convicciones religiosas o filosóficas, afiliación sindical, datos genéticos, biométricos, de salud o de orientación sexual).

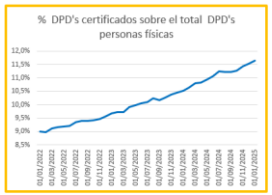
  - LOPD:
    - Colegios profesionales.
    - Centros docentes.
    - Entidades que exploten redes y presten servicios de comunicaciones electrónicas.
    - Prestadores de servicios de la sociedad de la información si elaboren a gran escala perfiles de los usuarios.
    - Entidades de crédito, financieras, aseguradoras, servicios de inversión y solvencia patrimonial.
    - Distribuidores y comercializadores de energía eléctrica y de gas natural.
    - Entidades de publicidad y prospección comercial (elaboración de perfiles).
    - Centros sanitarios.
    - Operadores de juego.
    - Empresas de seguridad privada.
    - Federaciones deportivas cuando traten datos de menores de edad.

Delegado de Protección de Datos (DPD)

- Nivel del puesto adecuado para relacionarse con la Dirección, evitando posibles conflictos de intereses y quedando garantizada su independencia:
  - En AAPP, un DPD nivel 30 en cada Ministerio y varios DPDs secundarios en centros dependientes. En EELL, se permite compartir DPD a nivel de Diputación.
  - Puede ser un DPD externo a la organización, contratado.
- Conocimientos tanto jurídicos, como tecnológicos y del negocio de la organización. La AEPD promueve un esquema de certificación, no obligatorio, para certificar DPDs:
  - ENAC acredita a las entidades certificadoras conforme a la norma UNE-EN ISO/IEC 17024 de certificación de personas y al propio Esquema AEPD-DPD.
  - Prerrequisitos de formación y experiencia, méritos adicionales puntuables (certificaciones), superación de un examen.







Medidas de adaptación de aplicaciones y entornos

- Resultado de los principios y obligaciones expuestas, las organizaciones deben realizar un conjunto de medidas a llevar a cabo para la adaptación de las aplicaciones y sus entornos a la normativa de protección de datos personales:

Deber de información
Consentimiento expreso

Registro de Actividades de Tratamiento (RAT)

Gestión de riesgos
Evaluación de impacto de protección de datos (EIPD)

Protección desde el diseño y por defecto
Minimización, seudonimización o anonimización de datos

Medidas de seguridad (ENS)

Respuesta a brechas de seguridad

Portabilidad de los datos
Derecho de supresión

Deber de información

- Antes de proceder a la recogida de datos personales, las aplicaciones deben informar al interesado en dos niveles. En primer lugar, se ofrecerá una información básica y resumida, y en caso de ser de interés para la persona afectada, se ofrecerá acceso a una segunda capa con información adicional y detallada.

	1ª Capa	2ª Capa
Responsable	Identidad del responsable.	Los datos de contacto del responsable, del representante y del Delegado de Protección de Datos.
Finalidad	Descripción sencilla de los fines del tratamiento y la elaboración de perfiles.	Una descripción ampliada de los fines de tratamiento con los plazos y criterios de conservación de los datos, y si existiesen las decisiones automatizadas, elaboración de perfiles y lógica.
Legitimación	Base jurídica del tratamiento.	La base jurídica del tratamiento, cuando esté basada en la obligación legal, interés público o interés legítimo, así como la obligación o no de facilitar datos y las consecuencias de su negativa.
Destinatarios	Si está previsto o no realizar cesiones o transferencia a terceros países.	Los destinatarios o categorías de destinatarios en las cesiones y transferencias, así como la adecuación, garantías y normas corporativas vinculantes.
Derechos	La forma de llevar a cabo el ejercicio de sus derechos.	Información detallada sobre como ejercer los derechos de acceso, rectificación, supresión, portabilidad, limitación u oposición, así como la forma de retirar el consentimiento expreso y la forma de realizar una reclamación ante la Autoridad de Control.
Origen datos	La procedencia de los datos cuando esta no sea el propio interesado.	Detalle sobre el origen de los datos, así como sus categorías. Esta información se ofrecerá incluso cuando su origen sea de acceso público.

- En todo caso, la información ofrecida deberá presentarse en un lenguaje conciso, claro y sencillo.

Bases de legitimación

- El RGPD mantiene el principio de que todo tratamiento necesita apoyarse en una base que lo legitime. Estas bases son:

  - Consentimiento.
  - Relación contractual.
  - Interés vital del interesado o de otras personas.
  - Obligación legal del responsable del tratamiento.
  - Interés público o ejercicio de poderes públicos, establecidos por ley.
  - Interés legítimo prevalente del responsable o de terceros a los que se comunican los datos.

- Como medida de adaptación, hay que revisar las bases identificadas y actualizar alguna en caso de que sea necesario (por ejemplo, obteniendo de forma expresa el consentimiento o apoyándose en otra base legal para continuar con el tratamiento).

Consentimiento expreso

- Consentimiento del interesado (definiciones del artículo 4): toda manifestación de voluntad libre, específica, informada e inequívoca por la que el interesado acepta, ya sea mediante una declaración o una clara acción afirmativa, el tratamiento de datos personales que le conciernen.

- Por tanto, el consentimiento deber ser explícito y deja de ser válido el consentimiento tácito. Muchos responsables tuvieron que volver a recabar el consentimiento de esta manera con la entrada en vigor del RGPD.

- Por ejemplo, deberá incorporarse en la aplicación una casilla que tenga que seleccionar activamente el usuario, o incluso realizar una firma electrónica, de forma que quede constancia en el sistema la acción que demuestra el acto de consentimiento expreso del interesado.

- En la redacción de estos consentimientos se deberá utilizar un lenguaje claro y sencillo.

- Además, cuando se preste el consentimiento para múltiples finalidades, deberá habilitarse que el interesado pueda dar el consentimiento por cada una de ellas de forma diferenciada.

- En todas las aplicaciones se deberá ofrecer información detallada de la forma que se habilita para que el interesado puede retirar el consentimiento.

Artículo 30: Cada responsable y, en su caso, su representante llevará un registro de las actividades de tratamiento efectuadas bajo su responsabilidad. Dicho registro deberá contener toda la información indicada a continuación:

a) Nombre y datos de contacto del responsable y, en su caso, del corresponsable, del representante del responsable, y del DPD.

b) Los fines del tratamiento.

c) Una descripción de las categorías de interesados y de las categorías de datos personales.

d) Las categorías de destinatarios a quienes se comunicarán los datos personales.

e) En su caso, las transferencias de datos personales a un tercer país o una organización internacional.

f) Cuando sea posible, los plazos previstos para la supresión de las diferentes categorías de datos.

g) Cuando sea posible, una descripción general de las medidas técnicas y organizativas de seguridad.

- El responsable y el encargado deben mantener el RAT, comunicando cualquier modificación al DPD.
- Debe ser un documento vivo, en revisión continua. En formato claro y legible.
- A disposición de la Autoridad de Control cuando lo solicite (auditable).
- Organizaciones de menos de 250 trabajadores exentas, a menos que el tratamiento pueda entrañar un riesgo para los derechos y libertades de los interesados, sea un tratamiento no ocasional o incluya categorías especiales de datos o datos relativos a condenas e infracciones penales.

Registro de las Actividades de Tratamiento (RAT)

[Enlace RAT Ministerio Hacienda](#) *Ejemplo de un tratamiento de la OIP de la IGAE:*

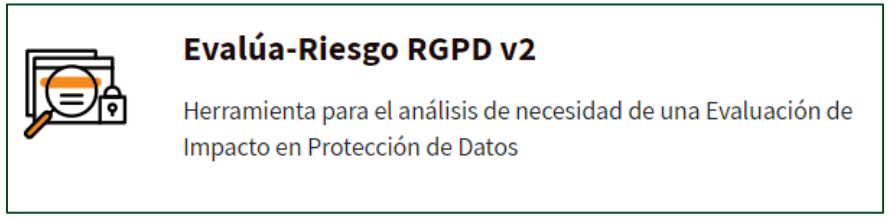
TRATAMIENTOS DE LA OFICINA DE INFORMÁTICA PRESUPUESTARIA COMO RESPONSABLE	ÚLTIMA ACTUALIZACIÓN	RESPONSABLE/ CORRESPONSABLE	DELEGADO DE PROTECCIÓN DE DATOS	FINES DEL TRATAMIENTO	BASE LEGAL
Autorizaciones de acceso a los sistemas de información de la Administración Presupuestaria	20/03/2025	Dirección de la Oficina de Informática Presupuestaria C/Mateo Inurria, 15 28071 Madrid sgsi@igae.hacienda.gob.es https://www.pap.hacienda.gob.es/	Subdirección General de Coordinación de la Información, Datos, Servicios Web y Transparencia. C/ Alcalá 9, 28071. Madrid. DPDHacienda@hacienda.gob.es http://www.hacienda.gob.es	Gestión de autorizaciones de acceso a los sistemas de información y servicios proporcionados por la Administración Presupuestaria.	RGPD: 6.1.c) Tratamiento necesario para el cumplimiento de una obligación legal aplicable al responsable del tratamiento. De conformidad con el artículo 8 de la LOPDGDD la base legal se sustenta entre otras normas: Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público. Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica Resolución de 21 de diciembre de 2015, de la Secretaría de Estado de Presupuestos y Gastos, por la que se regula la política de seguridad de los sistemas de información de la Secretaría de Estado de Presupuestos y Gastos y de la Intervención General de la Administración del Estado. Resolución de 27 de marzo de 2024, de la Intervención General de la Administración del Estado, por la que se regula la política de seguridad de la información de la Secretaría de Estado de Presupuestos y Gastos, de la Secretaría General de Fondos Europeos y de la Intervención General de la Administración del Estado.

CATEGORIAS DE INTERESADOS	CATEGORIAS DE DATOS PERSONALES	CATEGORIAS DE DESTINATARIOS	TRANSFERENCIAS INTERNACIONALES	PLAZO DE SUPRESIÓN	MEDIDAS TÉCNICAS Y ORGANIZATIVAS DE SEGURIDAD
Empleados. Usuarios externos	Identificativos/contacto. Nombre y apellidos. DNI / NIF. Dirección (postal, electrónica). Teléfono. Puesto de trabajo.	No están previstas. Sin perjuicio que puedan ser comunicados a autoridades públicas en cumplimiento de una obligación legal y en el ejercicio de sus competencias.	No están previstas transferencias internacionales	Los datos se conservarán durante el tiempo necesario para cumplir con la finalidad para la que fueron recabados y para determinar las posibles responsabilidades derivadas de dicha finalidad. Finalizado este período se suprimirán	Las medidas de seguridad implantadas se corresponden con las previstas en el Anexo II (Medidas de seguridad) del Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica y que se encuentran descritas en los documentos que conforman la Política de protección de datos y seguridad de la información del Ministerio de Hacienda.

- Son varias las ocasiones en que el RGPD expone la idea de que cuando existen tratamientos de datos personales, es necesario realizar una gestión del riesgo con el fin de determinar las medidas para garantizar los derechos y libertades de las personas (artículos 24, 25, 32. etc.).

- Como veremos más adelante, la AEPD ofrece la herramienta Evalúa-Riesgo RGPD v2, que tiene como objeto servir de ayuda a responsables y encargados a:
  - Identificar los factores de riesgo para los derechos y libertades de los interesados.
  - Hacer una primera evaluación del riesgo intrínseco, incluyendo la necesidad de realizar una EIPD.
  - Estimar el riesgo residual si se utilizan medidas de mitigación.

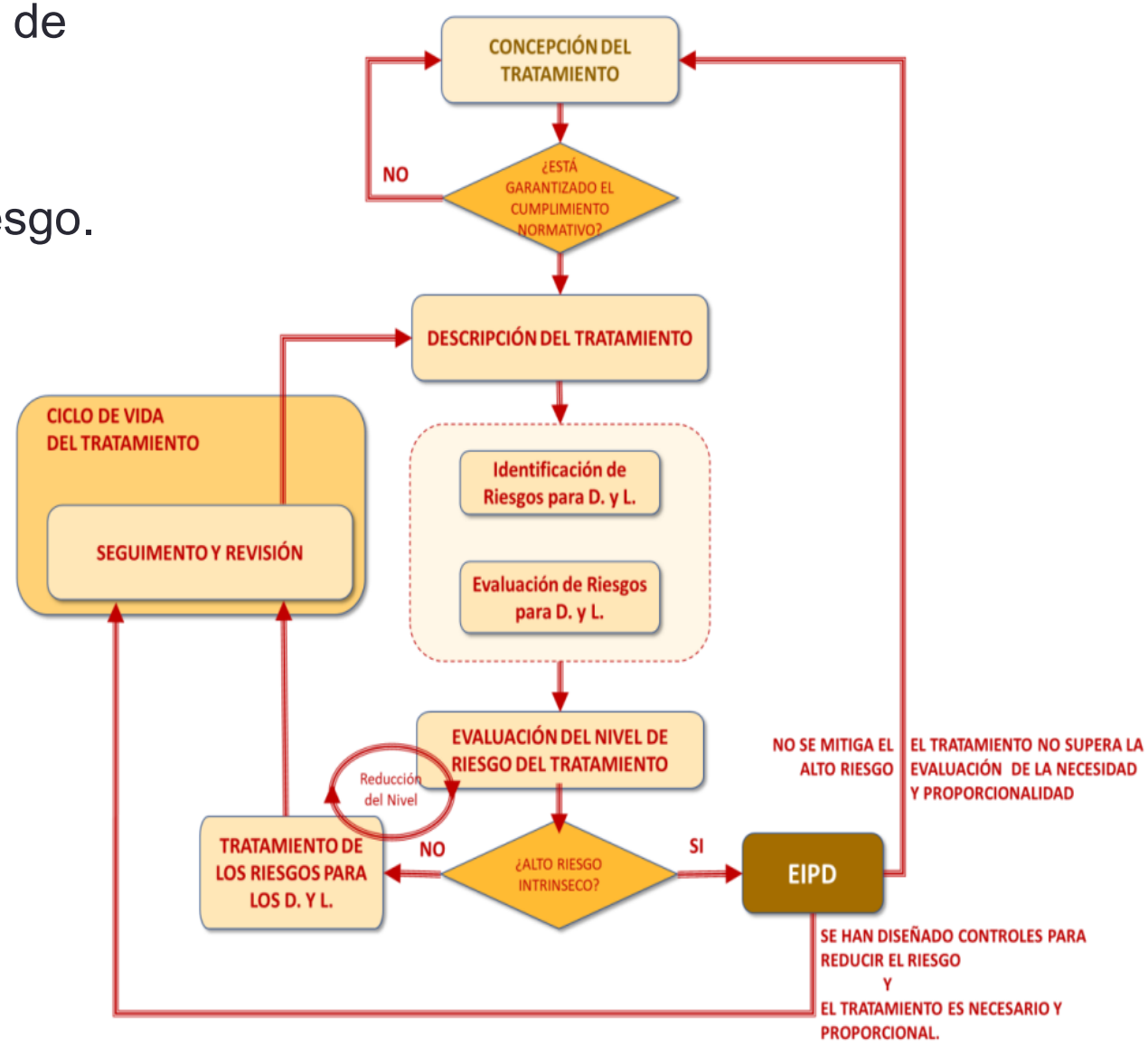
- También la Guía de Gestión del riesgo y evaluación de impacto en tratamientos de datos personales de la AEPD ofrece ideas interesantes, como las expuestas a continuación.





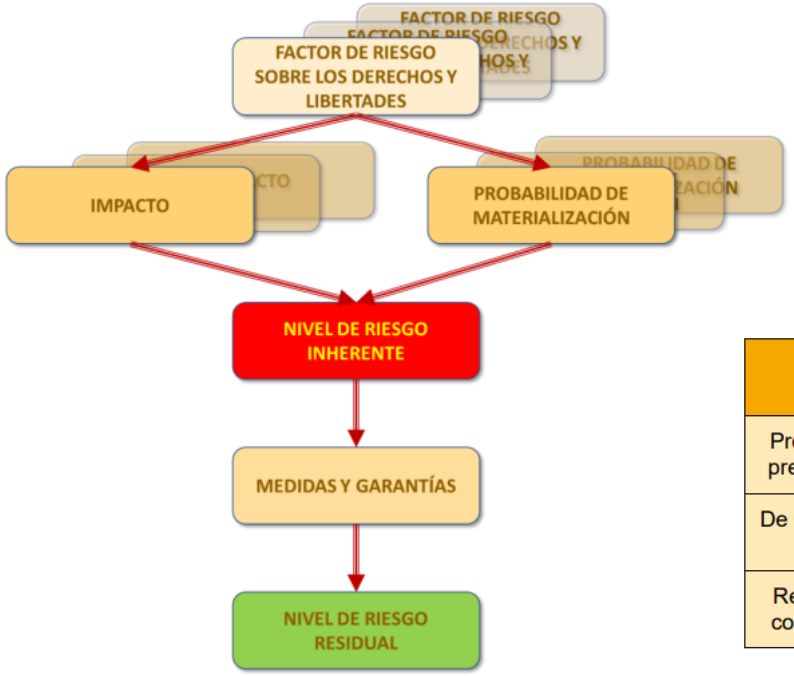
- La gestión del riesgo como un proceso: esquema de actividades a alto nivel.
- Alineamiento con la ISO 31000 de Gestión del riesgo.
- Integración de la EIPD en la gestión del riesgo: cuando el tratamiento entrañe un alto riesgo.



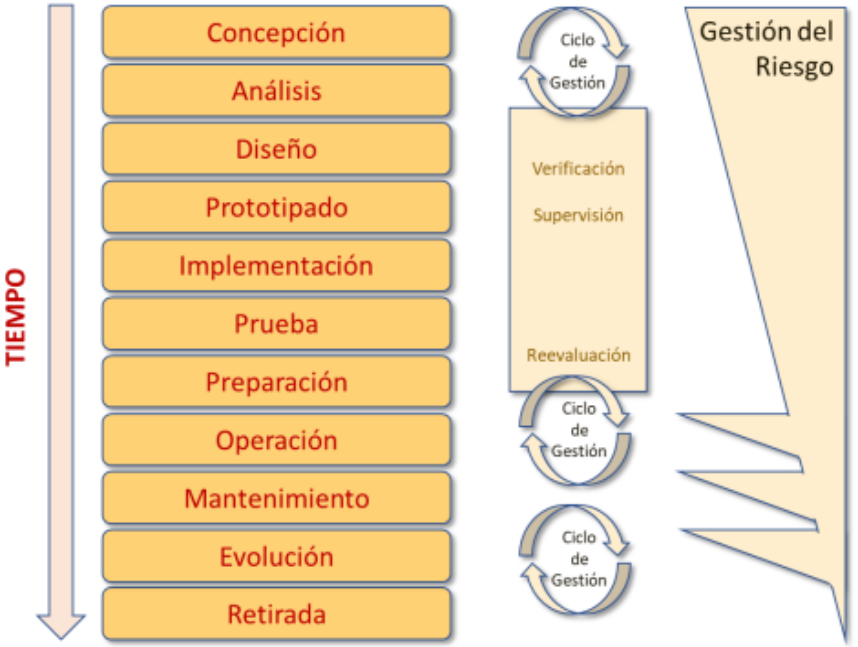


Gestión del riesgo

- Distinción entre riesgo inherente (antes de tomar medidas) y riesgo residual (después).
- Diversos tipos de medidas propuestas: preventivas, reactivas, legales, técnicas, etc.
- Gestión del riesgo a lo largo de todo el ciclo de vida del tratamiento.



Gestión del Riesgo para los Derechos y Libertades				
Proactivas/ preventivas	Garantías legales	Garantías técnicas	Garantías organizativas	Reducir/ mitigar
De detección				Evitar/ eliminar
Reactivas/ correctivas				Aceptar/ asumir



- **Riesgo** = **Probabilidad** x **Impacto**

Probabilidad	Muy alta	Medio	Alto	Muy alto	Muy alto
	Alta	Bajo	Alto	Muy alto	Muy alto
	Baja	Bajo	Medio	Alto	Muy alto
	Improbable	Bajo	Bajo	Medio	Muy alto
		Muy limitado	Limitado	Significativo	Muy significativo
		Impacto			

- Nivel de riesgo y categoría ENS:

Nivel de riesgo para los derechos y libertades	Categoría ENS
Muy Alto	Alto
Alto	Alto
Medio	Medio
Bajo	Bajo

- Categorías de factores de riesgo, mismas que Evalúa-Riesgo v2:

Operaciones relacionadas con los fines de tratamiento	Factores de riesgo que se derivan del fin declarado del tratamiento y otros fines vinculados al propósito principal.
Tipos de datos utilizados	Factores de riesgo relacionados con el ámbito del tratamiento que se derivan de los datos recogidos, procesados o inferidos en el tratamiento.
Extensión y alcance del tratamiento	Factores de riesgo relacionados con el ámbito del tratamiento relativos al número de sujetos afectados, la diversidad de datos o aspectos tratados, la duración en el tiempo, el volumen de datos, la extensión geográfica, la exhaustividad sobre la persona, la frecuencia de recogida, etc.
Categorías de interesados	Factores de riesgo relacionados con el ámbito del tratamiento relativos a la categoría de interesados, como empleados, menores, mayores, personas en situación de vulnerabilidad, víctimas, discapacitados, etc.
Factores técnicos del tratamiento	Factores de riesgo que se derivan de la naturaleza del tratamiento al implementarse con determinadas características técnicas o tecnologías.
Recogida y generación de datos	Factores de riesgo que se derivan de la naturaleza del tratamiento al recogerse o generarse datos de forma específica.
Efectos colaterales del tratamiento	Factores de riesgo que se derivan del contexto del tratamiento al poder generarse consecuencias no contempladas en los propósitos originales previstos del tratamiento.
Categoría del responsable/encargado	Factores de riesgo que se derivan del contexto específico del sector de actividad, modelo de negocio o tipo de entidad.
Comunicaciones de datos	Factores de riesgo que se derivan del contexto en el que se realizan las comunicaciones de datos a terceros en el marco del tratamiento.
Brechas de seguridad	Factores de riesgo que se derivan de la posible materialización de brechas de seguridad sobre los datos personales.

Evaluación de Impacto relativa a la Protección de Datos (EIPD)

Artículo 35:

- Cuando un tratamiento entrañe un **alto riesgo** para los derechos y libertades de las personas físicas, el responsable del tratamiento realizará una **EIPD**.

- Se requerirá EIPD en caso de:

  a) evaluación sistemática y exhaustiva de aspectos personales de personas físicas, como la elaboración de perfiles, y sobre cuya base se tomen decisiones que produzcan efectos jurídicos.

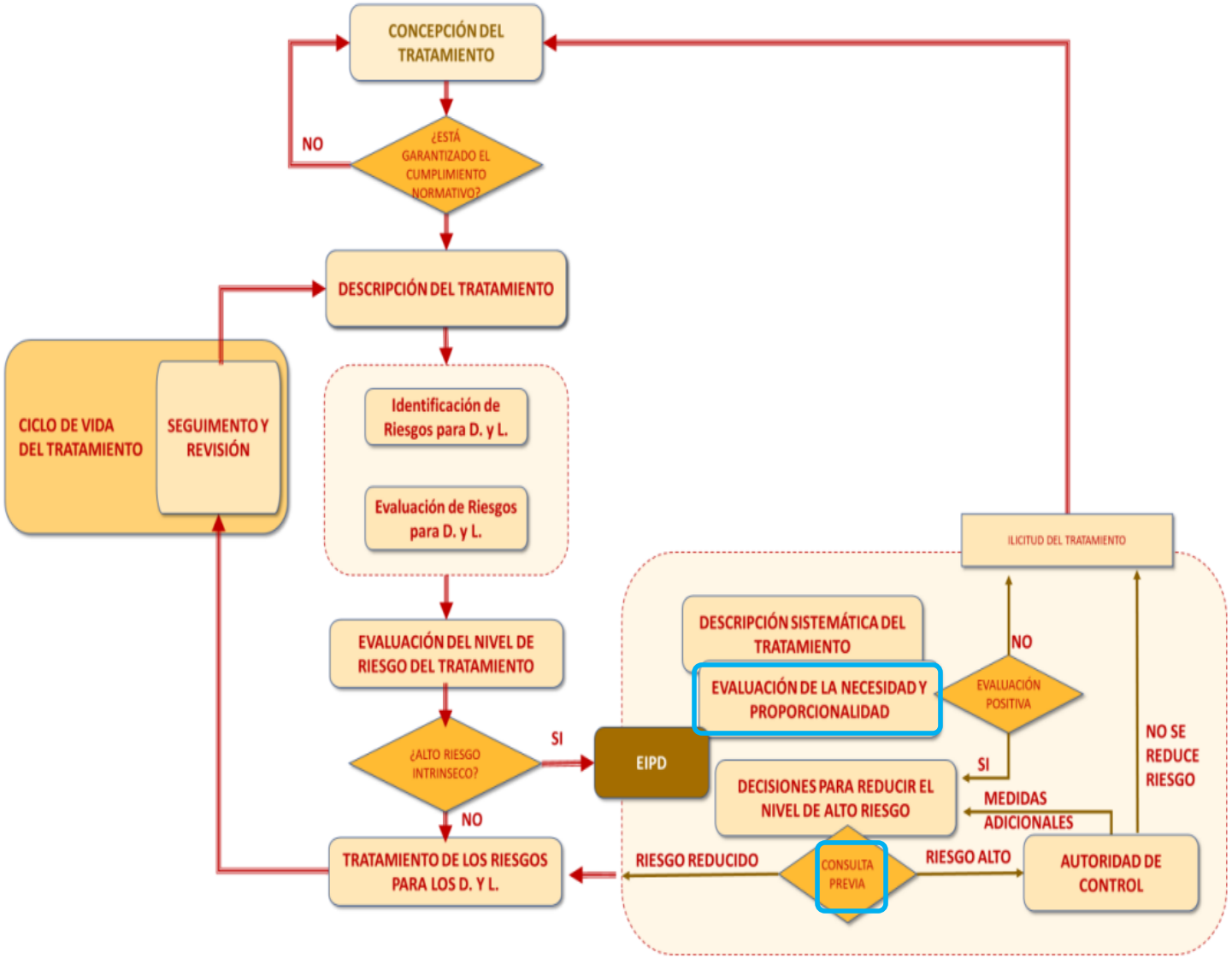
  b) tratamiento a gran escala de las categorías especiales de datos o de infracciones penales.

  c) observación sistemática a gran escala de una zona de acceso público.

- Se publicarán listas más concretas.

- La EIPD incluirá:
  a) Descripción sistemática de las operaciones y fines del tratamiento,
  b) Evaluación de la **necesidad** y la **proporcionalidad** de las operaciones del tratamiento respecto a su finalidad.
  c) Evaluación de los riesgos para los derechos y libertados de los interesados.
  d) Medidas previstas para afrontar los riesgos.

- EIPD integrada en la gestión del riesgo, a destacar:
  - La evaluación de la **necesidad** y **proporcionalidad** del tratamiento.
  - La **consulta previa** del responsable a la Autoridad de Control, antes de proceder al tratamiento, cuando la EIPD muestre que el tratamiento entrañaría un alto riesgo si el responsable no toma medidas para mitigarlo (artículo 36).



Noticia: AEPD sanciona a AENA por no hacer EIPD

Listado de tratamientos que SÍ requieren una EIPD

1. Tratamientos que impliquen **perfilado** o **valoración de sujetos**.
2. Tratamientos que impliquen la toma de **decisiones automatizadas** (como formar parte de un contrato).
3. Tratamientos que impliquen la observación, **monitorización**, supervisión, geolocalización o control del interesado de forma sistemática y exhaustiva (por ejemplo, a través de redes, aplicaciones o zonas de acceso público).
4. Tratamientos que impliquen el uso de **categorías especiales de datos** o datos relativos a condenas o infracciones penales.
5. Tratamientos que impliquen el uso de datos **biométricos** o **genéticos**.
6. Tratamientos que impliquen el uso de datos a **gran escala**.
7. Tratamientos que impliquen la asociación o **combinación** de datos de dos o más **tratamientos** con finalidades diferentes o por responsables distintos.
8. Tratamientos de datos de **sujetos vulnerables** o en riesgo de exclusión social (menores, personas con discapacidad, víctimas de violencia de género, etc.).
9. Tratamientos que impliquen la utilización de **nuevas tecnologías** o un uso **innovador** de tecnologías consolidadas.
10. Tratamientos de datos que **impidan** a los interesados **ejercer** sus **derechos**, utilizar un servicio o ejecutar un contrato.

Lista completa AEPD

Listado de tratamientos que NO requieren una EIPD

1. Tratamientos autorizados con anterioridad al RGPD por las Autoridades de Control.

2. Tratamientos con códigos de conducta, siempre y cuando una EIPD completa haya sido realizada para la validación del mismo.

3. Tratamientos que sean necesarios para el cumplimiento de una obligación legal, misión realizada en interés público o en el ejercicio de poderes públicos, siempre que en el mismo mandato legal no se obligue a realizar una EIPD.

4. Tratamientos realizados por trabajadores autónomos que ejerzan de forma individual, en particular médicos, profesionales de la salud o abogados, sin perjuicio de que pueda requerirse cuando el tratamiento que lleven a cabo cumpla de forma significativa con dos o más criterios establecidos en la lista de tratamientos que sí requieren una EIPD.

5. Tratamientos obligatorios por ley y realizados con relación a la gestión interna del personal de las PYMES con finalidad de contabilidad, gestión de recursos humanos y nóminas, seguridad social y salud laboral, pero nunca relativos a los datos de los clientes.

6. Tratamientos realizados por comunidades de propietarios.

7. Tratamientos realizados por colegios profesionales y asociaciones sin ánimo de lucro para la gestión de los datos personales de sus propios asociados y donantes.

Lista completa AEPD

Protección desde el diseño y por defecto

- Artículo 25 (parecido al 32 de seguridad del tratamiento): Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la **seudonimización** o la **minimización** de datos.

    - **Seudonimización**: tratamiento de datos personales de manera tal que ya no puedan atribuirse a un interesado sin utilizar información adicional, siempre que dicha información adicional figure por separado y esté sujeta a medidas técnicas y organizativas destinadas a garantizar que los datos personales no se atribuyan a una persona física identificada o identificable.

    - **Minimización de datos**: principio relativo al tratamiento por el que los datos deben ser los adecuados, pertinentes y limitados a lo necesario en relación con los fines para los que son tratados (es decir, mínimos).

- Pensar en la protección de datos personales desde que se empieza a diseñar el tratamiento, con anterioridad al inicio del mismo.

Continúa el artículo 25 del RGPD:

- El responsable del tratamiento aplicará las medidas técnicas y organizativas apropiadas con miras a garantizar que, por defecto, solo sean objeto de tratamiento los datos personales que sean necesarios para cada uno de los fines específicos del tratamiento.

- Esta obligación se aplicará a la cantidad de datos personales recogidos, a la extensión de su tratamiento, a su plazo de conservación y a su accesibilidad.

- Tales medidas garantizarán en particular que, por defecto, los datos personales no sean accesibles, sin la intervención de la persona, a un número indeterminado de personas físicas.

- La protección desde el diseño y por defecto podrá ser objeto de evaluación en los mecanismos de certificación que se establezcan.

Minimización de datos

Para el pleno cumplimiento de este artículo 25, las estrategias principales para llegar a la protección desde el diseño y por defecto podrían ser:

1. **Minimizar**: recoger y tratar la mínima cantidad de datos posibles (selección, exclusión, eliminación tras el período de conservación).

2. **Abstraer**: limitar el uso de los datos personales mediante generalizaciones, agrupaciones e introducción de perturbaciones en vez de uso de datos exactos.

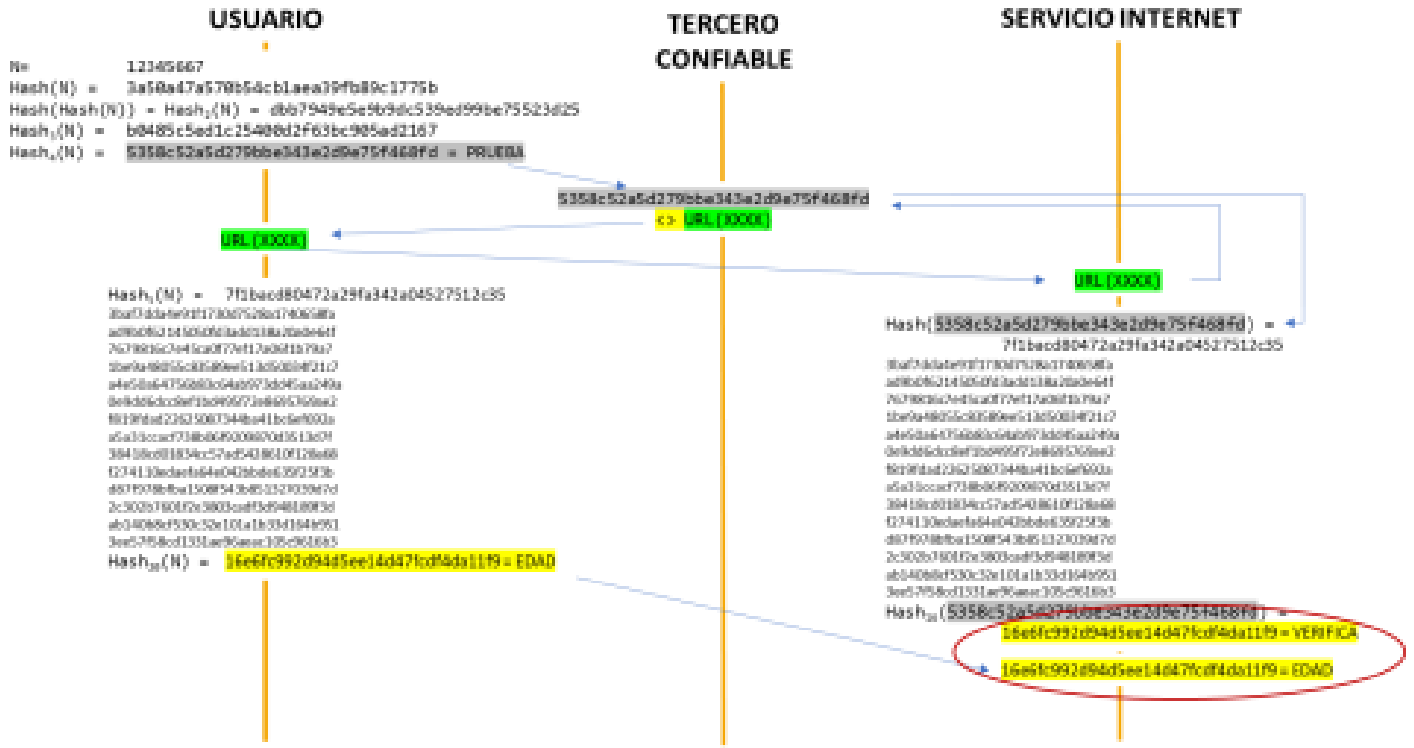
3. **Separar**: evitar el perfilado de sujetos mediante la recogida y almacenamiento aislado de los datos personales y la diseminación del tratamiento en subconjuntos independientes.

4. **Ocultar**: limitando la exposición de los datos personales, ofuscando datos para que sean ininteligibles o disociando los datos para que sean independientes y evitar correlaciones.

Existen servicios que pueden ser utilizados para evitar el almacenamiento de datos personales, como por ejemplo la PID, pero es importante que la integración y la implementación sea la correcta, de forma que no quede almacenado ningún dato personal y solo se utilicen en la comunicación que deberá estar cifrada.

Prueba de conocimiento cero o nulo (ZKP, Zero-Knowledge Proof)

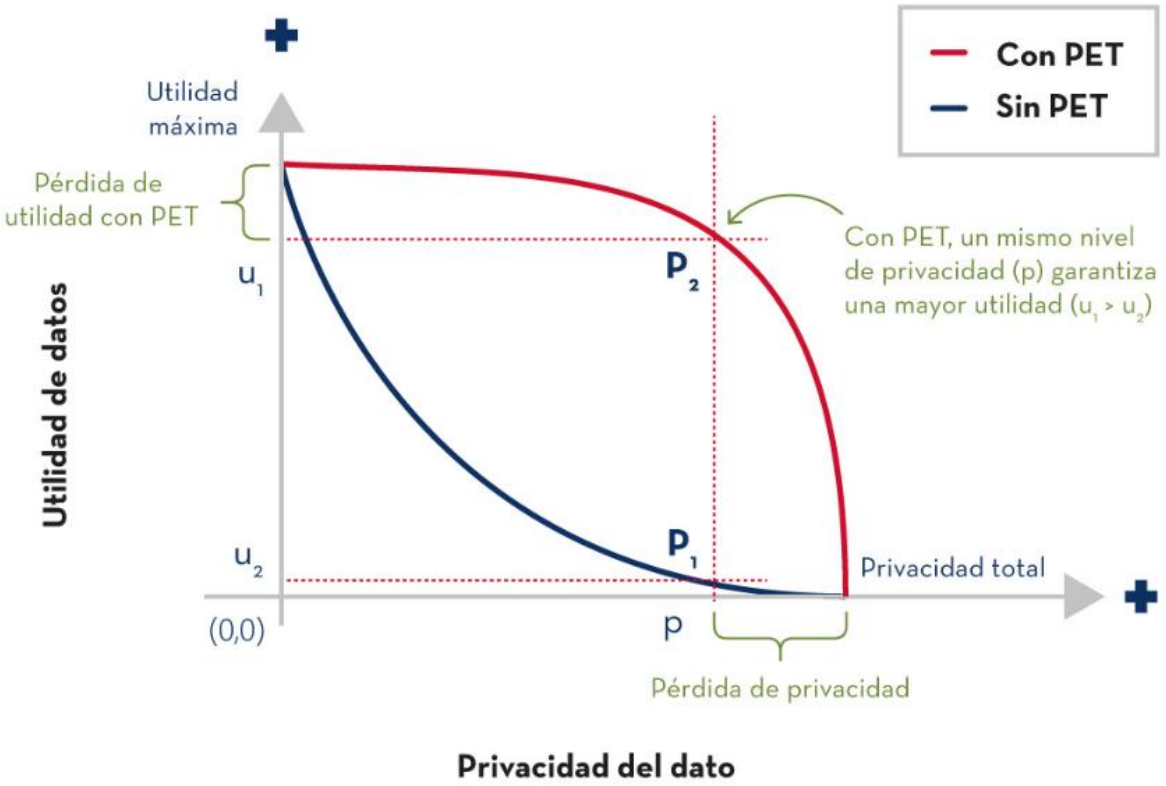
- Método criptográfico que permite a un parte demostrar a otra que dispone de cierta información o conocimiento (una contraseña, un dato personal) sin revelar el contenido del mismo.
- Permite así la verificación de una información sin la necesidad de exponer datos sensibles.
- Requiere la participación de un tercero de confianza y el empleo de técnicas de cifrado y funciones resumen o hash.
- Aplicaciones muy diversas: comprobación de límites de edad, nacionalidad, voto electrónico, compras, subastas, privacidad en blockchain, etc.

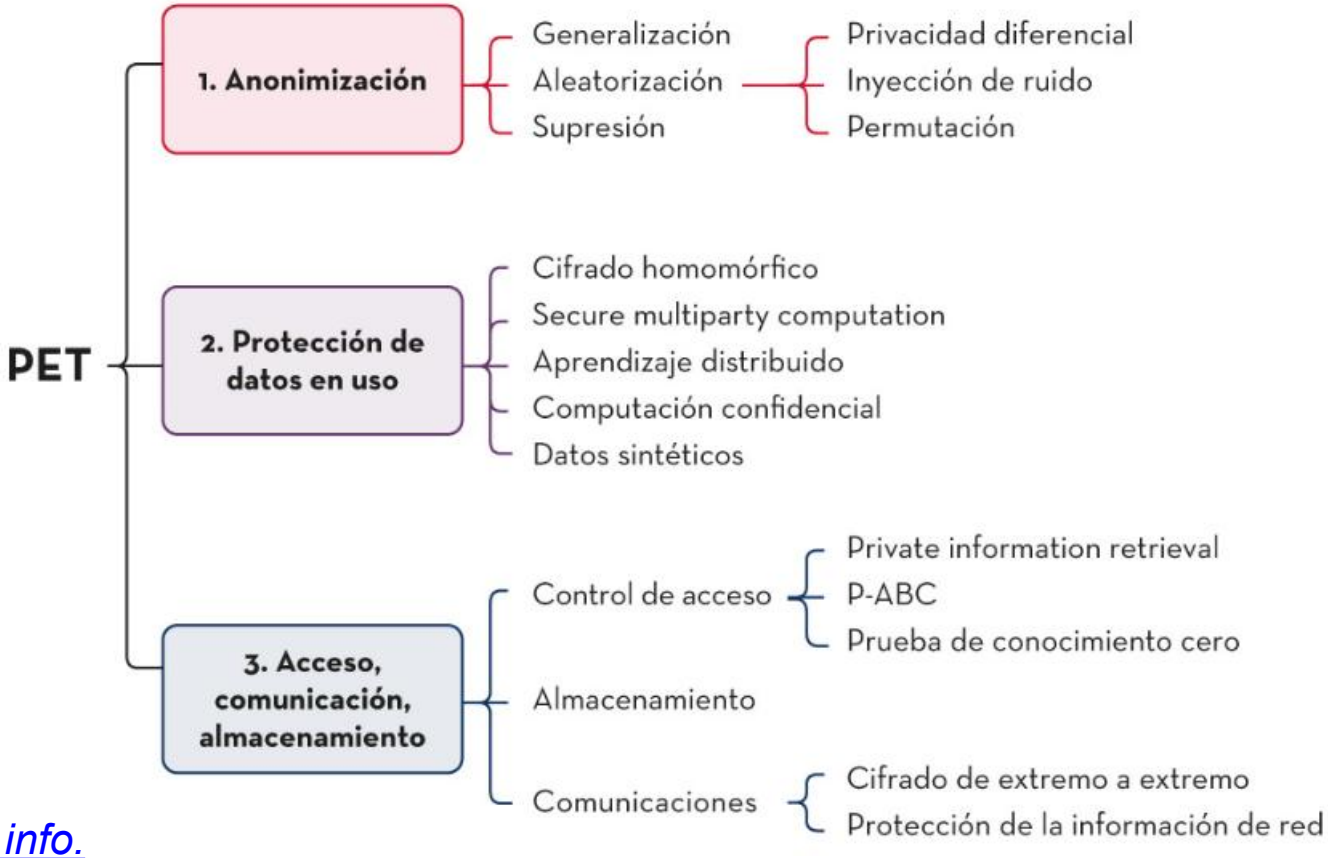


Ver artículo AEPD

Tecnologías PET (Privacy Enhancing Technologies)

- Conjunto de técnicas para mejorar la protección de la privacidad, minimizando datos, tratando de alcanzar un compromiso favorable entre la utilidad y la privacidad del dato.

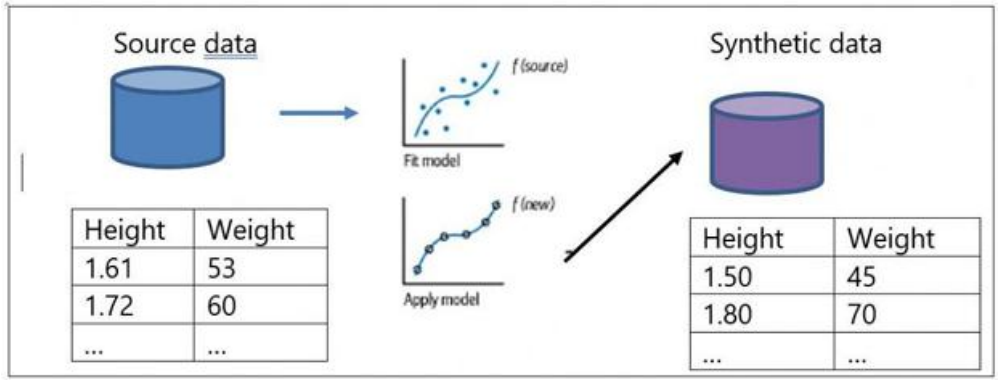


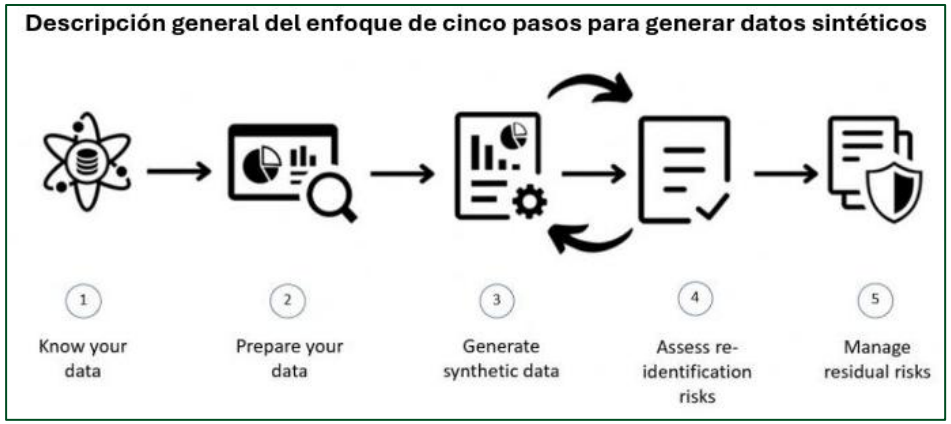


Más info.

Datos sintéticos

- Son datos generados artificialmente, diseñados para imitar las características y distribuciones de los datos reales, sin contener referencias personales o sensibles.
- Son, por tanto, una medida para proteger los datos personales.
- No están inherentemente libres de riesgos. La semejanza con los datos originales podría, en determinadas circunstancias, permitir la filtración de datos confidenciales o la reidentificación.
- Casos de uso: para entrenar modelos de IA, para pruebas, analítica y, en general, fomentar la economía del dato.
- Fuentes: Guía de la AEPD, Noticia PAe.







Seudonimización y anonimización de datos

- El considerando 26 del RGPD establece que los principios de protección de datos no deben aplicarse a la información anónima, es decir, información que no guarda relación con una persona física identificada o identificable, ni a los datos convertidos en anónimos de forma que el interesado no sea identificable.
    - Es decir, los datos **anonimizados** no son datos personales y por tanto no les aplica el RGPD, aunque pueden estar afectados por otras normas de seguridad.
    - En esta línea, en las aplicaciones y entornos de los sistemas de información, es posible generar datos anonimizados a partir de datos personales aplicando una transformación que debe asegurar que una información adicional no permita la reidentificación.
- En cambio, los datos **seudonimizados**, la información adicional vinculada a estos datos y el tratamiento que genera estos datos sí están bajo el ámbito del RGPD y, entre otras cuestiones:
    - Ha de impedirse la reidentificación sin disponer de la información adicional.
    - Hay que aplicar las medidas de seguridad determinadas en base al análisis de riesgos para proteger los derechos y libertades.
- Otra diferencia entre estos dos conceptos es que el proceso de anonimización genera un único y nuevo conjunto de datos, mientras que el proceso de seudonimización genera dos nuevos conjuntos de datos: la información seudonimizada y la información adicional que permite revertir la seudonimización.

Funciones hash

- Una técnica utilizada habitualmente tanto para la anonimización como para la seudonimización son las funciones hash o funciones resumen.

- Una función hash es un proceso que transforma cualquier conjunto arbitrario de datos en una nueva serie de caracteres de longitud fija, independiente del tamaño de los datos de entrada.

- Reconstruir el mensaje original a partir del resultado de la función hash debe ser extremadamente costoso, sino imposible.

- Para dificultar aún más la reidentificación, antes o después de la función hash se puede añadir un cifrado.

- La Guía CCN-STIC 807 (Criptología de empleo en el ENS) autoriza las funciones SHA-2 y SHA-3 (Secure Hash Algorithm) recomendado a partir de una fortaleza de 128 bits de nivel de seguridad (se requieren 2^{128} operaciones para romper el algoritmo criptográfico).

- En general los procesos de anonimización deben garantizar que tampoco el responsable del tratamiento pueda reidentificar a los individuos.

- Ver más en guía AEPD "Introducción al hash como técnica de seudonimización de datos personales".

Medidas de seguridad ENS

- La LOPD establece en su Disposición adicional primera, de título “Medidas de seguridad en el ámbito del sector público”, que las medidas de seguridad a implantar para el tratamiento de datos personales serán las determinadas por el Esquema Nacional de Seguridad, teniendo también en cuenta el RGPD.

- Acudiendo por tanto al Anexo II del RD 311/2022, cabría destacar por su relación con los tratamientos de datos personales las siguientes:

  - Datos personales [mp.info.1]

  - Criptografía [mp.si.2]

  - Protección de la confidencialidad [mp.com.2]

- También se recomienda apoyarse en las Guías CCN-STIC como, por ejemplo:

  - CCN-STIC 804 ENS. Guía de Implantación, si bien su última actualización es de 2017, por lo que se refiere a las medidas del antiguo ENS RD 3/2010.

  - CCN-STIC 807. Criptología de empleo en el ENS, actualizada en mayo de 2022.

Datos personales [mp.info.1]

- Primera medida del grupo de medidas de protección (mp) de la información (info).

- Requisitos de la medida: cuando el sistema trate datos personales, el responsable de seguridad recogerá los requisitos de protección de datos que sean fijados por el responsable o por el encargado del tratamiento, contando con el asesoramiento del DPD, y que sean necesarios implementar en los sistemas de acuerdo a la naturaleza, alcance, contexto y fines del mismo, así como de los riesgos para los derechos y libertades de los interesados, de acuerdo a lo establecido en el RGPD, y de acuerdo a la evaluación de impacto en la protección de datos, si se ha llevado a cabo.

- Aplica al sistema independientemente de su categoría.

dimensiones	Todas		
categoría	BÁSICA	MEDIA	ALTA
	aplica	aplica	aplica

Criptografía [mp.si.2]

dimensiones	C I		
nivel	BAJO	MEDIO	ALTO
	n.a.	aplica	+ R1 + R2

- Segunda medida del grupo de medidas de protección (mp) de los soportes de la información (si).

- Esta medida se aplica, en particular, a todos los dispositivos removibles cuando salen de un área controlada. Se entenderán por dispositivos removibles, los CD, DVD, discos extraíbles, pendrives, memorias USB u otros de naturaleza análoga.

- Requisitos:
  1. Se usarán mecanismos criptográficos que garanticen la confidencialidad y la integridad de la información.
  2. Se emplearán algoritmos y parámetros autorizados por el CCN (Guía CCN-STIC 807).

- Refuerzos:

  R1: Se emplearán productos certificados conforme a [op.pl.5] de Componentes Certificados (Catálogo Productos CCN, CPSTIC).

  R2: Las copias se seguridad se cifrarán utilizando algoritmos y parámetros autorizados por el CCN.

Protección de la confidencialidad [mp.com.2]

dimensiones	C		
nivel	BAJO	MEDIO	ALTO
	aplica	+ R1	+R1+R2+R3

- Segunda medida de protección de las comunicaciones.
- Requisito: Se emplearán redes privadas virtuales cifradas (VPNs) cuando la comunicación discurra por redes fuera del propio dominio de seguridad.
- R1: Se emplearán algoritmos y parámetros autorizados por el CCN.
- R2: Se emplearán dispositivos hardware en el establecimiento y utilización de la VPN.
- R3: Se usarán productos o servicios certificados conforme a [op.pl.5] (Catálogo Productos CCN).
- R4: Se emplearán cifradores que cumplan con los requisitos establecidos en la guía CCN-STIC que sea de aplicación (Guía CCN-STIC 807).
- R5: Se cifrará toda la información transmitida.

Respuesta a brechas de seguridad

- Incidencias, quiebras, violaciones o brechas de seguridad: destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

- Se debe **notificar** la brecha a la Autoridad de Control competente sin dilación indebida y, a ser posible, dentro de las **72 horas** desde que se tenga constancia, a menos que sea improbable que la brecha suponga un riesgo para los derechos de los afectados (artículo 33).
  - Se deben documentar todas las brechas, pudiendo verificar dicha documentación.
  - Asesora Brecha, herramienta AEPD para valorar la obligación de notificar.

- Cuando sea probable que entrañe un **alto riesgo** además se **comunicará** a los interesados (artículo 34):
  - La comunicación incluirá recomendaciones sobre medidas para paliar las consecuencias de la quiebra.
  - No será necesaria la comunicación si los datos afectados son ininteligibles (cifrados).
  - Comunica-Brecha RGPD, herramienta AEPD para valorar la obligación de comunicar.

Derecho a la portabilidad de los datos

- El artículo 20 del RGPD establece que siempre que el tratamiento esté basado en el consentimiento o un contrato y se efectúe por medios automatizados, el interesado tendrá derecho a recibir los datos personales que le incumban, que haya facilitado a un responsable del tratamiento, en un formato estructurado, de uso común y lectura mecánica, y a transmitirlos a otro responsable.

- Más aún, el interesado tendrá derecho a que los datos personales se transmitan directamente de responsable a responsable cuando sea técnicamente posible.

- Este derecho tiene relación directa con la interoperabilidad entre las aplicaciones de los responsables.

- Para poder asegurar la portabilidad de los datos, las aplicaciones y entornos deberán generarlos y almacenarlos de forma que puedan ofrecerse en un formato estructurado, de uso común y legible por máquina (XML, JSON, por ejemplo).

- Para que los datos ofrecidos por los responsables del tratamiento sean realmente portables, junto con los datos se debe proporcionar también los metadatos suficientes y con el mayor nivel de detalle para preservar el significado exacto de la información.

- Esta obligación es importante tenerla en cuenta desde el diseño de las aplicaciones para que la recogida de la información ya genere los metadatos suficientes para su eventual portabilidad.

Se podrá ejercitar este derecho ante el responsable cuando concurra alguna de las siguientes circunstancias:

- Cuando los datos personales **ya no sean necesarios** en relación con los **fines** para los que fueron recogidos.
- Cuando el tratamiento se ha basado en el **consentimiento** y se **retira** el mismo, siempre que el citado tratamiento no se base en otra causa que lo legitime.
- Cuando el interesado se **oponga al tratamiento** y no prevalezca otro motivo legítimo para el mismo.
- Cuando los datos personales han sido **tratados ilícitamente**.
- Cuando los datos personales deban suprimirse para el cumplimiento de una **obligación legal** que se aplique al responsable del tratamiento.

Este derecho tiene su equivalente en el entorno de Internet y de las redes sociales con el denominado **derecho al olvido**, regulado en los artículos 93 y 94 de la LOPD de manera que:

- Toda persona tiene derecho a que los motores de búsqueda en Internet eliminen de las listas de resultados que se obtuvieran tras una búsqueda efectuada a partir de su nombre, los enlaces publicados que contuvieran información relativa a esa persona cuando fuesen inadecuados, inexactos, no pertinentes, no actualizados o excesivos o hubieren devenido como tales por el transcurso del tiempo, teniendo en cuenta los fines para los que se recogieron o trataron, el tiempo transcurrido y la naturaleza e interés público de la información.

- Toda persona tiene derecho a que sean suprimidos, a su simple solicitud, los datos personales que hubiese facilitado para su publicación por servicios de redes sociales y servicios de la sociedad de la información equivalentes.

- No obstante, este derecho no es ilimitado, de forma que puede ser factible no proceder a la supresión cuando el tratamiento sea necesario para el ejercicio de la libertad de expresión e información, para el cumplimiento de una obligación legal, por razones de interés público, etc.

En el ámbito del sector público, otros documentos que pueden ser relevantes para hacer efectivo este derecho de supresión, son:

- Guía CCN-STIC 105. Catálogo de Productos de Seguridad de las TIC (CPSTIC).
  - Apartado "Herramientas de borrado seguro":
    - Blancco Drive Eraser.
    - Blancco File Eraser.
    - Olvido.



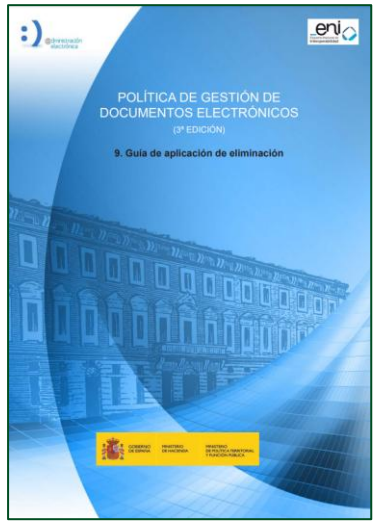
- Política de Gestión de Documentos Electrónicos (PAe): NTI, Guía, Política del Ministerio de Hacienda y Función Pública (2022), Modelos de políticas para entidades locales, Guía de aplicación de eliminación, etc.
  - Diferentes métodos de eliminación: borrado nivel 0 (lógico), borrado seguro niveles 1 y 2, destrucción segura (física).
  - Criterios: categoría ENS, datos personales (Sí/No), categorías especiales (Sí/No), etc.

Derecho de supresión









SOPORTES DE ALMACENAMIENTO Y MÉTODOS Y TÉCNICAS DE BORRADO Y DESTRUCCIÓN

		SOPORTES DE ALMACENAMIENTO				
		HDD	CINTA MAGNÉTICA	DISCO ÓPTICO WORM	DISCO ÓPTICO REGRABABLE	SSD
ELIMINACIÓN	**BORRADO (NIVEL 0) + CONTROL DE ACCESOS (+ cifrado)**					
	BORRADO (NIVEL 0)	X	X		X	X
	BORRADO SEGURO - NIVEL 1					
	SOBREESCRITURA (=3)	X				X
	BORRADO SEGURO - NIVEL 2					
	SOBREESCRITURA (=>4)	X				X
	COMANDO A NIVEL DE FIRMWARE	X				X
	BORRADO CRIPTOGRÁFICO	X				X
	DESMAGNETIZACIÓN	X	X			
	DESTRUCCIÓN SEGURA DE SOPORTES					
	TRITURACIÓN			X	X	
	DESINTEGRACIÓN		X			X
	APLASTAMIENTO	X				X
	PULVERIZACIÓN	X				

- Por último, como una medida más de adaptación de aplicaciones y entornos a la normativa de datos personales, conviene conocer la existencia de la ISO/IEC 27701:2025 de Sistemas de gestión de la información de privacidad.

- Norma diseñada para responsables y encargados del tratamiento de información de identificación personal (PII, Personally Identifiable Information) de cualquier organización.

- Hace de puente entre la ISO 27001 (SGSI) y el RGPD.

- Certificable, con la nueva versión de 2025 ya no es obligatorio contar previamente con la certificación ISO 27001 para obtener la de ISO 27701. Deja de ser una “simple extensión” de la ISO 27001 para convertirse en un estándar independiente.

- Para los DPD, esta norma proporciona una guía clara sobre cómo demostrar cumplimiento del RGPD.

- Más información: link1, link2.



Gobernanza protección de datos

- **Agencia Española de protección de datos** (AEPD):
  - Autoridad administrativa independiente (Ley 40/2015), adscrita al Ministerio de Justicia, actúa con plena independencia en el ejercicio de sus funciones.
  - Es la Autoridad de Control mencionada constantemente en el RGPD para España.

- **Comité Europeo de Protección de Datos**:
  - Encargado de supervisar el RGPD en la UE.
  - Compuesto por todas las autoridades nacionales de protección de datos (AEPD) y el Supervisor Europeo de Protección de Datos (SEPD).

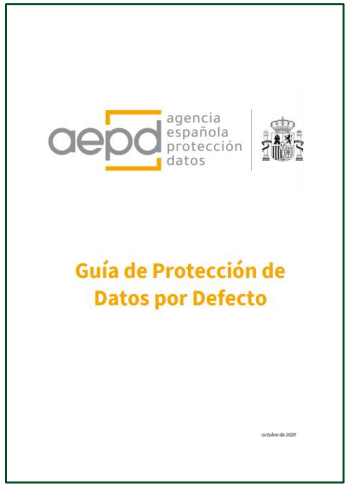
- **Supervisor Europeo de Protección de Datos**:
  - Encargado de supervisar que las instituciones y organismos de la UE cumplen el RGPD.
  - Se encarga de la secretaría del Comité.

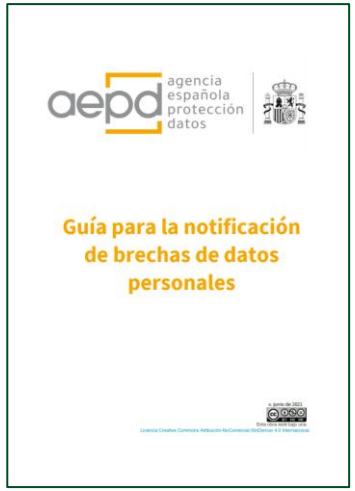
Guías AEPD





















Artículos interesantes

- *eIDAS2, EUDI Wallet y RGPD*

Herramientas

- Herramientas de la AEPD:
  - Gestiona, Facilita, Evalúa, Asesora, Comunica, etc.

- Herramientas de cifrado:
  - Guía CCN-STIC 105. Catálogo de Productos y Servicios de Seguridad de las TIC (CPSTIC).
  - Guía CCN-STIC 807. Criptología de empleo en el ENS.

- Herramientas de auditoría (soluciones de ciberseguridad del CCN):
  - Amparo, Inés, Pilar, etc.

- Herramientas de protección de datos de la AEPD:

Facilita RGPD 

Canal del DPD 

Facilita EMPRENDE 

Asesora Brecha 

Evalúa-Riesgo RGPD v2 

Comunica-Brecha 

Gestiona RGPD 

ValidaCripto RGPD 

- La mera obtención de los documentos que proporcionan estas herramientas no supone, en ningún caso, el cumplimiento automático de las obligaciones que el RGPD y la LOPD establecen para los responsables y encargados, en particular lo referido al principio de responsabilidad activa.

- Se trata de documentos iniciales de ayuda orientados a facilitar la comprensión de dichas obligaciones y abordarlas, inicialmente, de forma adecuada.

- ¿Eres una **PYME**? Prueba este asistente, te dirá qué tienes que hacer con tus tratamientos de datos personales de **escaso** nivel **riesgo**.

- Por ejemplo, datos personales de clientes, proveedores o recursos humanos.

- No podrá utilizarse para tratamientos que impliquen un alto riesgo para los derechos y libertades de las personas, como datos de salud o tratamientos masivos de datos, entre otros.

- Herramienta fácil y gratuita que permite realizar un análisis de riesgos muy básico.

- La herramienta genera:
  - El Registro de Actividades de Tratamiento (RAT).
  - Cláusulas informativas para incluir en los formularios de recogida de datos personales.
  - Cláusulas contractuales para los contratos con el encargado del tratamiento.
  - Anexo con medidas de seguridad orientativas consideradas mínimas.

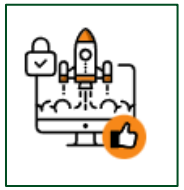


- Herramienta que persigue servir de apoyo a personas **emprendedoras** y **startups tecnológicas** cuyos tratamientos se caracterizan por un fuerte componente **innovador** que hace uso de nuevas tecnologías.

- Herramienta fácil de utilizar y gratuita basada en una serie de cuestionarios guiados que permiten caracterizar los tipos de tratamiento realizados por la empresa (igual que Facilita RGPD).

- Pero, a diferencia de Facilita RGPD, Facilita EMPRENDE sirve para **tratamientos** que suelen ir asociados a los modelos de negocio que puede **no** se correspondan con un escenario de **bajo riesgo**.
  - Ej: App que usa geolocalización para ofrecer sus servicios.

- Genera un conjunto de documentos adaptados que sirven de guía y apoyo para cumplir con la normativa (clausulas informativas, contractuales, RAT, registro de brechas, etc.).



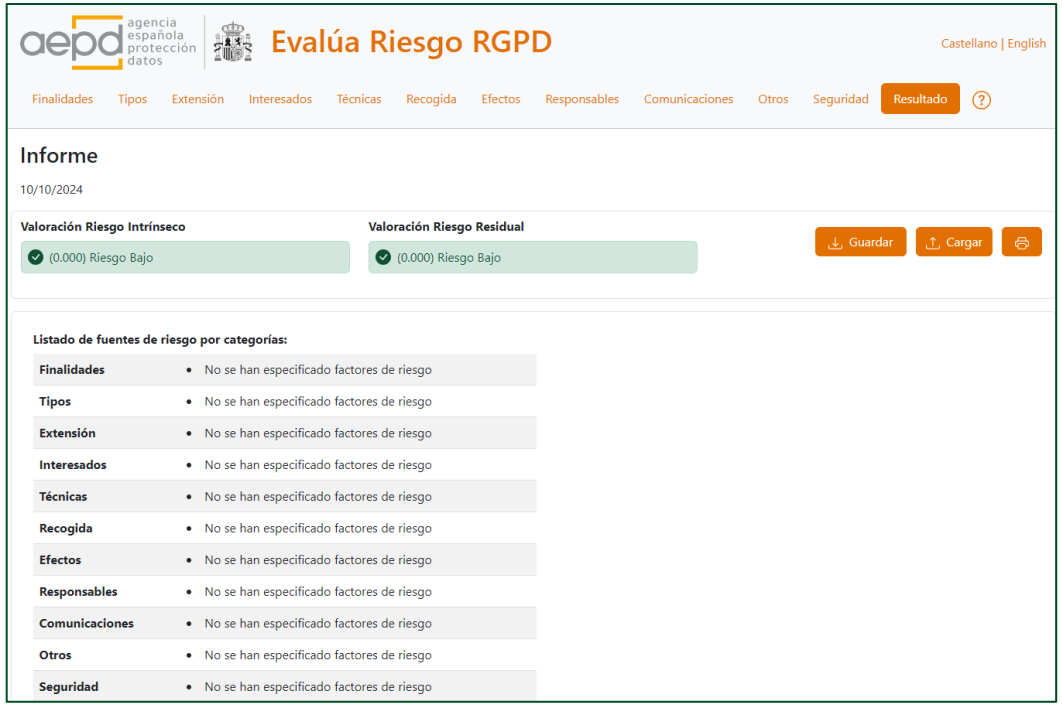
Evalúa-Riesgo RGPD v2

- Herramienta para el **análisis** de **necesidad** de una **EIPD**.

- Ayuda a:
  - Identificar los factores de riesgo para los derechos y libertades de los interesados cuyos datos están presentes en el tratamiento
  - Hacer una **primera evaluación** del **riesgo intrínseco**, incluyendo la **necesidad** de realizar una **EIPD**.
  - Estimar el riesgo residual si se utilizan medidas y garantías para mitigar los factores de riesgos específicos.

- Alineada con la guía de Gestión de riesgo y evaluación de impacto en tratamientos de datos personales.

- La valoración del riesgo para cada factor que efectúa la herramienta, así como el cálculo final, tiene carácter general y supone una evaluación mínima que, en su caso, tendrá que ser ajustada por el responsable para determinar el nivel de riesgo del tratamiento con precisión.



- Asistente para la gestión del **RAT**, la gestión del **riesgo** y soporte a la **EIPD**.

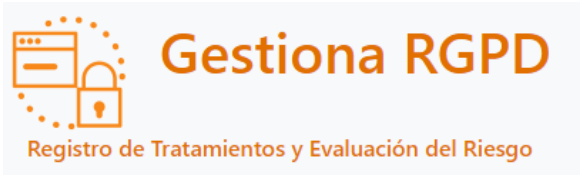
- Permite gestionar el RAT de una entidad, con hasta 500 tratamientos, de forma integrada y en diferentes formatos (doc, html, csv).

- Incorpora las funcionalidades de la herramienta Evalúa-Riesgo RGPD v2 para realizar el análisis de riesgos y la evaluación de la obligación (o conveniencia) de realizar una EIPD.

- Las funcionalidades se extienden permitiendo gestionar el riesgo con medidas sugeridas por la herramienta por cada factor de riesgo específico identificado, medidas para la gestión de brechas de datos personales, y medidas organizativas y políticas de protección de datos.

- Permite, en el caso de EIPD, documentar las evaluaciones de idoneidad, necesidad y proporcionalidad.

- La gestión del tratamiento se realiza en el propio navegador del usuario, sin transmisión alguna de datos a la AEPD y con total confidencialidad.



- Este canal tiene como finalidad atender las **consultas** planteadas por los **DPD** ante la AEPD.

- Las consultas, que se formulan a través de la sede electrónica de la AEPD, se atenderán en consideración a su contenido y repercusión, así como a razones de eficiencia y optimización de recursos.

- Desde este canal **no** se atenderán:
  - Cuestiones planteadas desde un punto de vista hipotético ni las que pudiesen estar relacionadas con procedimientos que esté tramitando la AEPD, incluidas las relativas al estado de tramitación.
  - Las que pretendan la validación de documentos elaborados por responsables y encargados, por cuanto que es responsabilidad exclusiva de aquéllos con arreglo al principio de proactividad.
  - Solicitudes de acceso a la información pública.
  - Las consultas que se hayan presentado por el Canal de la Ciudadanía.
  - Las consultas que se refieran a cuestiones que se encuentran ya explicadas y son accesibles en los materiales publicados en la página web de la AEPD, tales como las Guías y Preguntas Frecuentes.



- Herramienta para valorar la obligación de **notificar** una brecha de datos personales sin dilación indebida a la **Autoridad** de control.

- Recodamos matiz del artículo 33: “hay que notificar, a menos que sea improbable que la brecha suponga un riesgo para los derechos de los afectados”.

- Herramienta sencilla y gratuita, que una vez finalizada su ejecución, los datos aportados se eliminan, por lo que la AEPD en ningún caso puede conocer la información que haya sido aportada.

- Es una herramienta de ayuda a la toma de decisiones, pero esta última corresponde ineludiblemente a la persona responsable de tratamiento y en ningún caso su utilización representa el pronunciamiento de la Agencia sobre una brecha de seguridad concreta.



- Con esta herramienta el responsable del tratamiento puede obtener una valoración que le asista en la toma de decisiones sobre la obligación de **comunicar** a las **personas** afectadas por una brecha de seguridad de los datos personales.

- Recordamos artículo 34: hay que comunicar cuando sea probable que entrañe un **alto riesgo**.

- Con los datos introducidos por el responsable se generan unos documentos que pueden ser útiles para la eventual comunicación.

- Se trata de una herramienta de ayuda a la toma de decisiones.

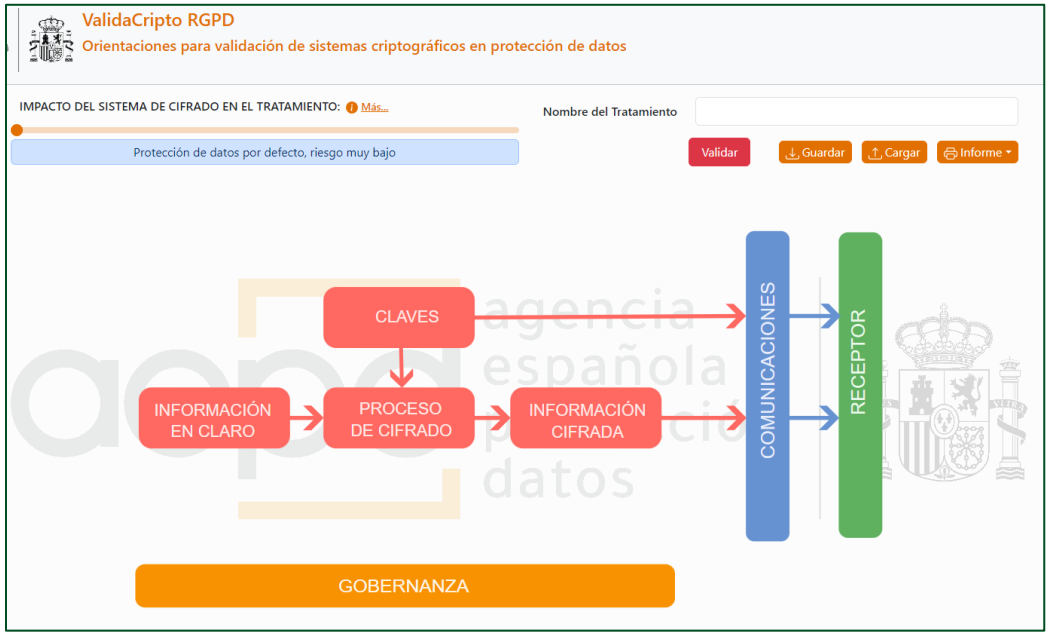


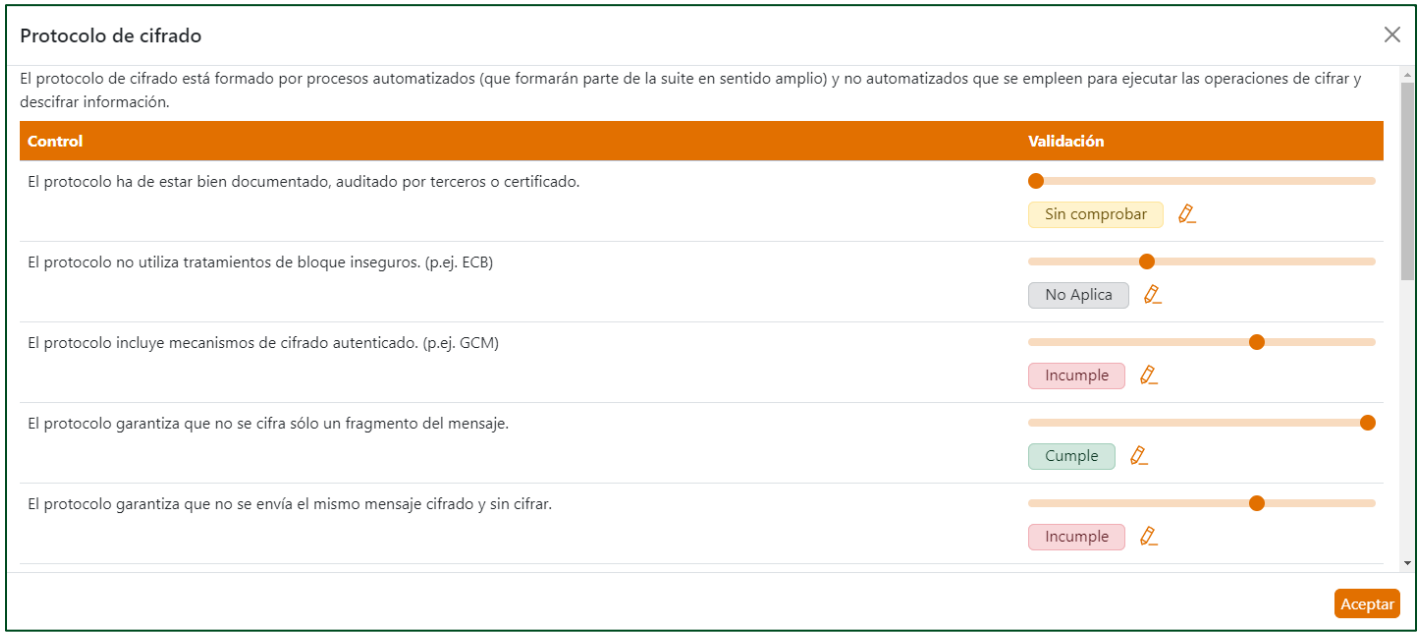
- Herramienta que ayuda a evaluar los sistemas de cifrado para facilitar el cumplimiento de la normativa analizando cada uno de los elementos del proceso de cifrado.

- Herramienta que traslada de forma ágil e intuitiva la metodología de evaluación propuesta en las Orientaciones para la validación de sistemas criptográficos en la protección de datos.



- Conjunto de controles sobre cada dominio: las claves, el proceso de cifrado, gobernanza, etc.





Herramientas de cifrado

- El cifrado es la aplicación de un algoritmo que produce que la información pase a un estado ilegible.

- Referencias al cifrado en RGPD:
  - Artículo 32: Seguridad del tratamiento: establece el cifrado y la seudonimización como posibles medidas de seguridad apropiadas.

  - Artículo 34: Comunicación brecha seguridad al interesado: no será necesaria si los datos personales afectados están cifrados.

- Protege fundamentalmente la dimensión de confidencialidad de la información, tanto en su almacenamiento como en su comunicación.

- Sólo con la clave del algoritmo (uno de los parámetros de la fórmula) se puede descifrar la información.

- Hay dos grandes familias de algoritmos criptográficos:
  - Algoritmos asimétricos o criptografía de clave pública.
  - Algoritmos simétricos o criptografía de clave privada.

Algoritmos simétricos o de clave secreta/privada:

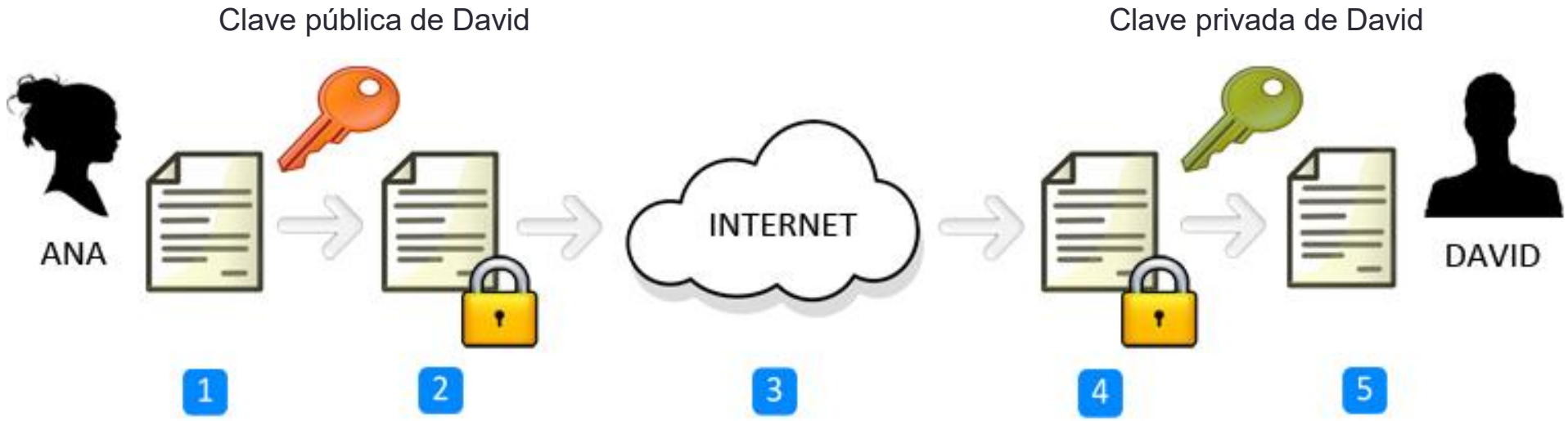
- Una única clave para cifrar y descifrar.
- Más rápido, pero problema de hacer llegar la clave secreta a destino.
- Ej: **AES** (Advanced Encryption Standard).

Algoritmos asimétricos o de clave pública.

- Dos claves vinculadas:
  - **Clave privada** solo conocida por el propietario.
  - **Clave pública** de libre acceso. Podría considerarse un dato personal según AEPD.
- Dos funciones principales:
  - **Cifrar** (garantizar confidencialidad):
    - Emisor cifra con clave pública del receptor.
    - Solo el receptor, con su clave privada, puede descifrar la información.
  - **Firmar** (garantiza autenticidad, no repudio e integridad):
    - Emisor cifra mensaje con su clave privada.
    - Receptor descifra con la clave pública del emisor.
- Más lento, pero no hay problema de canal inseguro.
- Ej: **RSA**, **SSL/TLS**

Cifrado asimétrico

Para cifrar:



Para firmar:



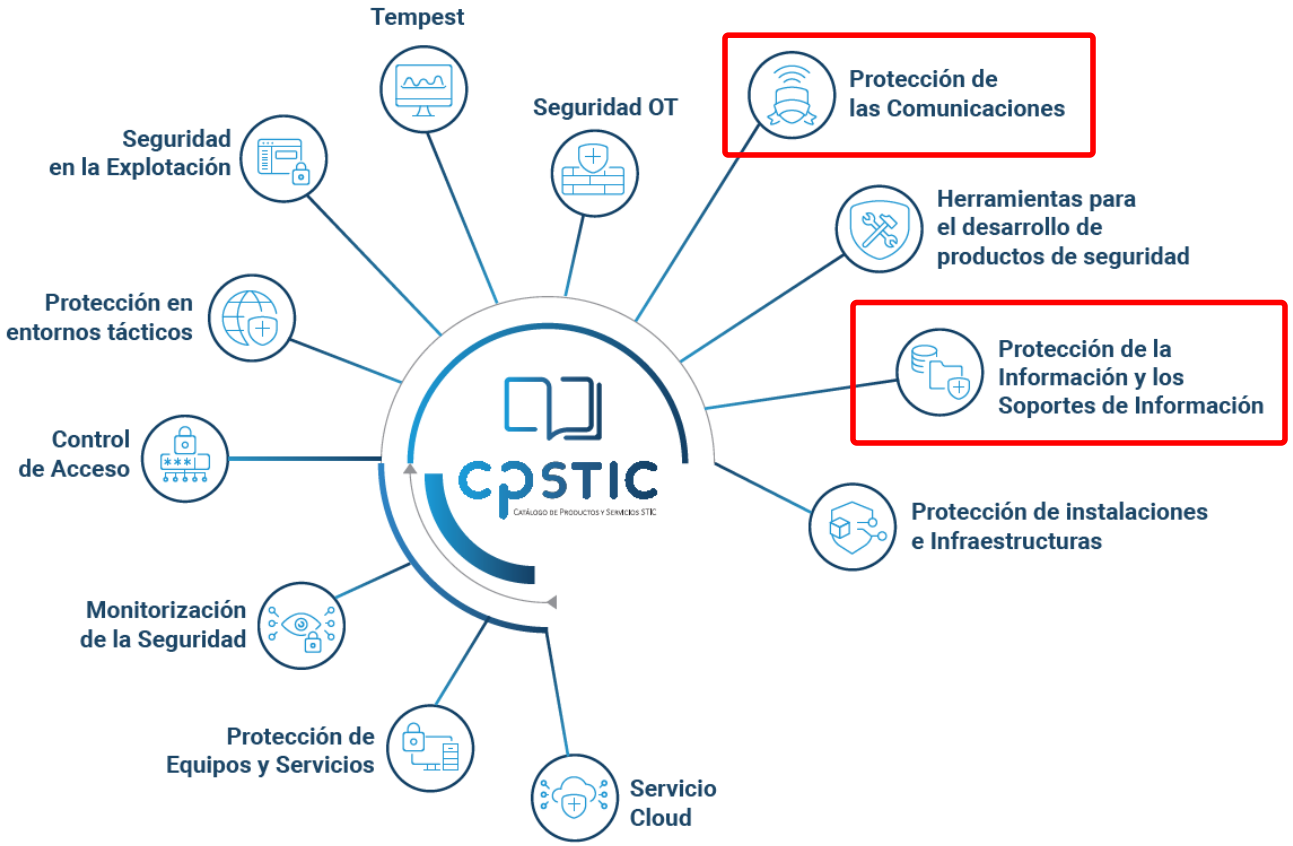
Catálogo de Productos y Servicios de Seguridad de las TIC (CPSTIC)

- Productos certificados por el CCN, facilita a la selección de productos confiables.
- Disponible tanto en portal web como en Guía CCN-STIC 105 (se actualiza mensualmente).

- Tres listados:
  - Productos **cualificados**: adecuados para sistemas bajo el alcance del **ENS**.
  - Productos **aprobados**: adecuados para el manejo de **información clasificada**.
  - Productos y servicios de conformidad y gobernanza de la seguridad: facilitan la gestión o implementación de medidas de seguridad de un sistema de información.
    - Pilar, Ángeles y de empresas.

- Organizados en torno a diferentes categorías generales y familias de productos: firewalls, routers, switches, antivirus, cifradores, armarios apantallados, móviles, etc.

Productos de cifrado cualificados. CPSTIC



Taxonomía completa desarrollada en [Guía CCN-STIC 140]

Protección de la información	Almacenamiento cifrado de datos	[mp.si.2]; [mp.info.3]	F.1	
	Cifrado y compartición segura de información	[mp.si.2]; [mp.info.3]	F.2	
	Herramientas de Borrado Seguro	[mp.si.5]	F.3	
	Sistemas de prevención de fugas de datos	[mp.info.2]	F.4	
	Gestión de metadatos	[mp.si.1]; [mp.info.5] Transversalmente: [op.mon.3]	F.5	
	Copias de seguridad	[mp.info.9]	F.6	
	Sistemas de Gestión de Bases de Datos (DBMS)	Control y requisitos de acceso. Configuración de seguridad Inventario de activos Mantenimiento y actualizaciones de seguridad	F.7	
Soporte criptográfico	Herramientas para firma electrónica	[mp.info.4]; [mp.info.5]	L.1	
	Módulo de Seguridad Hardware (HSM)	[mp.si.2]; [mp.info.3]	L.2	
	Infraestructura PKI	[mp.si.2]; [mp.info.3]	L.3	
	Dispositivos para gestión de claves criptográficas	[op.exp.11]	L.4	

Productos de cifrado cualificados. CPSTIC

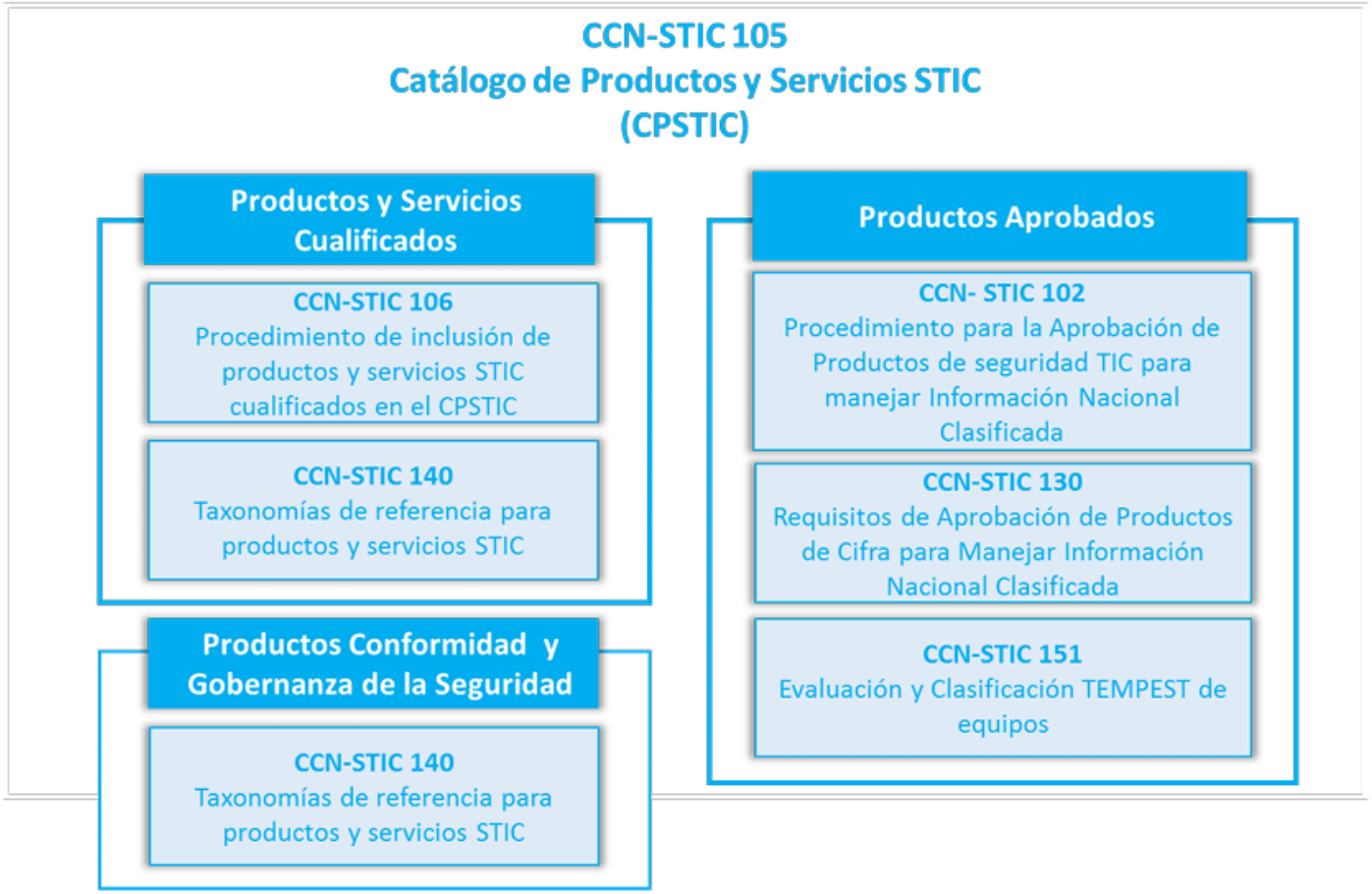


Figura 1. Clasificación del CPSTIC

TIPO DE PRODUCTO O SERVICIO	INFORMACIÓN QUE MANEJA
APROBADO	CLASIFICADA
CUALIFICADO	SENSIBLE (ENS)
CONFORMIDAD Y GOBERNANZA DE LA SEGURIDAD	CUALQUIER TIPO

Guía CCN-STIC 140

	Certificación	Cualificación	Aprobación
Nivel de confianza	+	++	+++
Certificación Funcional	✓	✓ + CCN-STIC-140	✓ + CCN-STIC-140 + CCN-STIC-130
Declaración de seguridad validada por el CCN	X	✓	✓
Sistemas que manejan Información Clasificada (si aplica)	X	X	✓
Procedimiento de empleo seguro verificado por el CCN	X	✓	✓
Incluido en CPSTIC	X	✓	✓
Ámbito de utilización	No específico	Sistemas bajo el alcance del ENS	Sistemas que manejan Información Clasificada

Common criteria LINCE

Infografías

Productos de cifrado cualificados. CPSTIC

Epicom

EP880 V2.08.36 y V2.09.35

Listado: Aprobado,Cualificado
Fabricante: Epicom
Categoría: Protección de la Información
Familia: Cifrado y compartición segura de información
Tipo: Producto
Nivel clasificación: DIFUSIÓN LIMITADA
Aprobado desde: 01/07/2021
Aprobado hasta: 31/12/2026
Categoría ENS: Alta
Cualificado desde: 01/07/2021
Cualificado hasta: 31/12/2026

Microsoft

Azure Managed HSM

Listado: Cualificado
Fabricante: Microsoft
Categoría: Soporte Criptográfico
Familia: Hardware Security Module (HSM)
Tipo: Servicio
Categoría ENS: Alta
Cualificado desde: 25/10/2024
Cualificado hasta: 30/09/2026

CISCO

Cisco AnyConnect Secure

Listado: Cualificado
Fabricante: Cisco Systems
Categoría: Protección de las Comunicaciones
Familia: Redes privadas virtuales: SSL
Tipo: Producto
Categoría ENS: Alta
Cualificado desde: 01/11/2022
Cualificado hasta: 30/06/2026

Mecanismos criptográficos autorizados

- Mecanismos autorizados por el CCN, para su uso en el ENS, en las guías:
  - Guía CCN-STIC 807. Criptología de empleo en el ENS.
  - Guía CCN-STIC 221. Guía de mecanismos autorizados (más detalle).

- Clasificados en dos categorías:

  - Recomendados (R): mecanismos que ofrecen un nivel adecuado de seguridad a largo plazo. Cualquier riesgo residual, solo podrá proceder del desarrollo de ataques muy innovadores.

  - Heredado o Legacy (L): mecanismos con una implementación muy extendida a día de hoy, pero que ofrecen un nivel de seguridad aceptable solo a corto plazo. Deben dejar de utilizarse en un corto plazo de tiempo porque el estado del arte ha demostrado que su garantía de seguridad se ha visto comprometida.





Mecanismos criptográficos autorizados

- **Cifrado simétrico**: basados en AES con longitud de clave y fortaleza de 128, 192 o 256 bits.
- **Cifrado asimétrico**: entre otros, RSA (L>2048, R>3000).
- **Funciones resumen** (**hash**): SHA-2 y SHA-3 (recomendado a partir de 128 bits).
- **TLS** (Transport Layer Security, sucesor de SSL): protocolo seguro de comunicaciones muy extendido con HTTPS. No se autoriza el uso de versiones inferiores a 1.2 y 1.3.
- **SSH** (Secure Shell): usado en administración remota de sistemas, dispositivos de red, etc. Única versión autorizada SSH v2.
- **IPsec**: para crear VPNs (Virtual Private Networks) a través de redes inseguras. Modo túnel siempre que sea posible, frente a modo transporte que es menos seguro.

Antes de exponer algunas de las herramientas de auditoría más relevantes, conviene repasar conceptos fundamentales en torno a la obligatoriedad de las auditorías:

Auditoría de protección de datos

- El RGPD y LOPD **no** establecen ningún **plazo** como **obligación** para realizar una auditoría de protección de datos. Será la AEPD quien podrá acordar la realización de planes de auditoría preventiva, referidos a los tratamientos de un sector concreto de actividad (artículo 54 LOPD).

- El artículo 32 del RGPD de seguridad de tratamiento indica que, entre las posibles medidas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, **podrá haber** un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas.

Auditoría de seguridad

- El artículo 31 del ENS establece que los sistemas de información dentro del ámbito del ENS serán objeto de una **auditoría regular ordinaria**, al menos cada **dos años**.

Por tanto, las herramientas expuestas a continuación se centran en esta auditoría obligatoria ENS.

- Catálogo de soluciones de ciberseguridad cada vez más extenso. A destacar en el ámbito de la auditoría:
  - **Inés**, **Amparo** y **Pilar**
  - Ana y Clara (en un segundo o tercer escalón)

ADA
Plataforma avanzada de análisis de malware

AMPARO
Implantación de seguridad y conformidad del ENS

ANA
Automatización y normalización de auditorías

LORETO
Almacenamiento en la nube

LUCIA
Sistemas de Gestión Federada de Tickets

MARTA
Análisis avanzados de ficheros

CARMEN
Defensa de ataques avanzados/APT

CLARA
Auditoría de Cumplimiento ENS/STIC en Sistemas Windows

CLAUDIA
Herramienta para la detección de amenazas complejas en el puesto de usuario

MÓNICA
Gestión de eventos e información de seguridad

OLVIDO
Borrado seguro de datos

metaOLVIDO
Gestión de metadatos

microCLAUDIA
Centro de vacunación

ELENA
Simulador de Técnicas de Cibervigilancia

ELSA
Exposición Local y Superficie de Ataque

PILAR
Análisis y Gestión de Riesgos

REYES
Intercambio de Información de Ciberamenazas

VANESA
Grabaciones y emisiones de vídeo en streaming

GLORIA
Gestor de logs para responder ante incidentes y amenazas

INES
Informe de Estado de Seguridad en el ENS

IRIS
Estado de la ciberseguridad

Y además: ángeles Formación y Talento en Ciberseguridad

INÉS: **IN**forme del **E**stado de la **S**eguridad en el ENS.

- Solución desarrollada para la gobernanza de la ciberseguridad, que permite evaluar regularmente el estado de la seguridad de los sistemas del ENS (a.32), además de su adecuación e implantación al ENS.

- La plataforma permite la recogida de información organizada, delegada y supervisada de forma continua a lo largo de todo el año. Consolida datos de >1.000 organismos y >22.000 sistemas.

- Además, permite la creación de un **Plan de Adecuación** al ENS, para priorizar y planificar las tareas a realizar en las primeras fases de la adecuación, entre otras:
  - Elaborar la Política de Seguridad y resto de documentación del marco normativo.
  - Categorización del sistema.
  - Realizar un análisis de riesgos.
  - Solicitar la auditoría para obtener la conformidad (AMPARO).

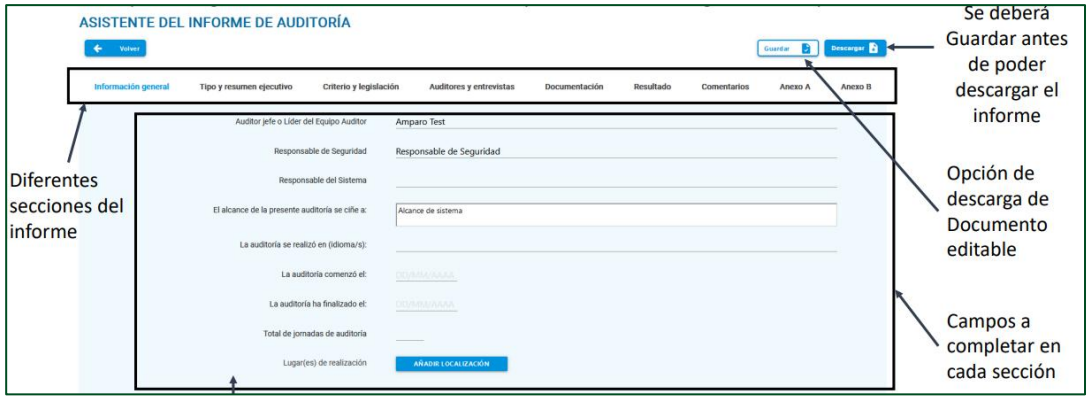


AMPARO

- Asistente para la conformidad del ENS. Asistente de Auditoría Completa.
- Solución desarrollada para la gobernanza de la ciberseguridad (como Inés) de uso exclusivo para las Entidades de Certificación (EC) y Órganos de Auditoría Técnica (OAT).
- Incorpora funcionalidades para facilitar los procesos de auditoría de conformidad y de gestión de la certificación, entre otras:
  - Mantener la comunicación con la organización auditada, ver el estado del sistema y facilitar todo el proceso de auditoría.
  - Remitir y notificar el resumen de hallazgos de auditoría al CCN.
  - Disponer de una sección de Documentos de Conformidad donde poder incorporar el Plan de Auditoría, Informe de Auditoría, Certificado de Conformidad y cualquier otro documento relevante.
  - **Notificar** los **Certificados de Conformidad** para ser publicados en el Portal de Gobernanza.
  - Disponer de un módulo de análisis de datos.

Herramientas del CCN







[Fuente]

PILAR: **P**rocedimiento **I**nformático-**L**ógico para el **A**nálisis de **R**iesgos

- Conjunto de herramientas EAR (Entorno de Análisis de Riesgos) cuya función es el análisis y la gestión de riesgos de un sistema de información siguiendo la metodología **Magerit** (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información).

- Útil para la caracterización y valoración de activos, amenazas, riesgos y salvaguardas.

- Herramienta generalista, pero también **módulos específicos** de cumplimiento de **ENS** y del **RGPD**.

- Diferentes versiones:
  - PILAR: versión íntegra de la herramienta.
  - PILAR Basic: versión sencilla para PYMES y EELL.
  - µPILAR: versión reducida a la mínima expresión para realizar análisis de riesgos muy rápidos.
  - RMAT (Risk Management Additional Tools): herramientas más avanzadas.





ANA: **A**utomatización y **N**ormalización de **A**uditorías

- Sistema de auditoría continua que tiene por objetivo incrementar la capacidad de vigilancia y conocer la superficie de exposición.

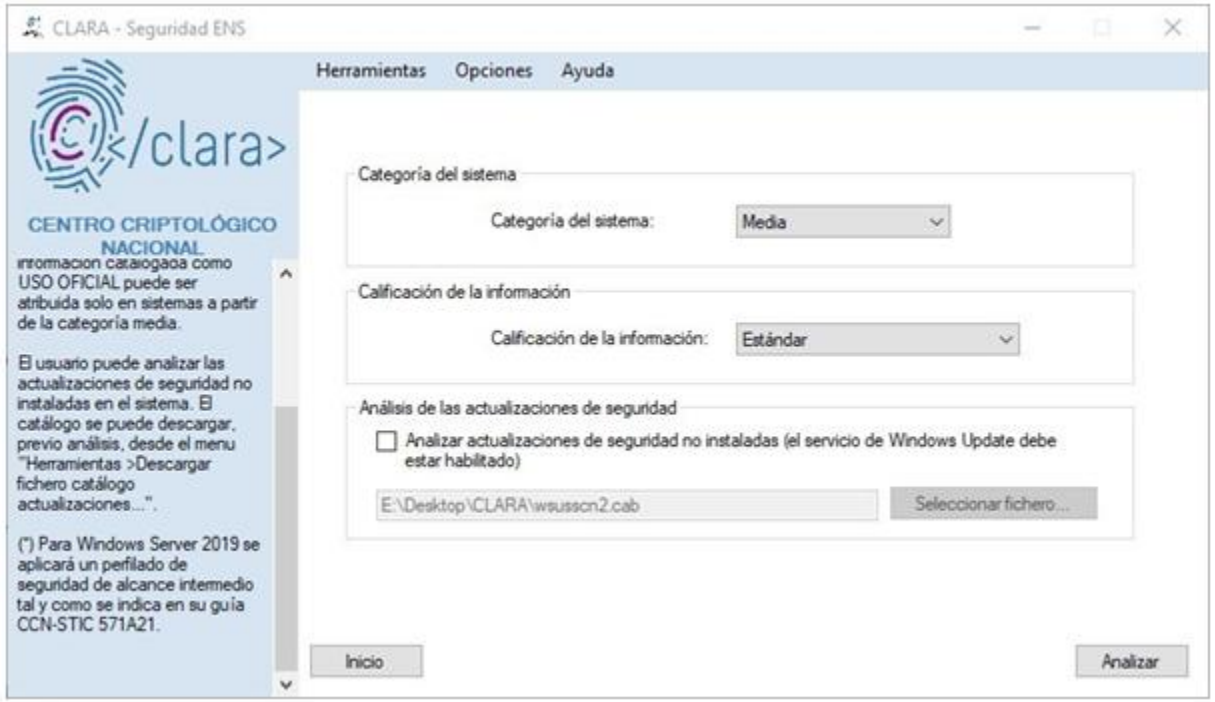
- Con esta herramienta se pretende reducir los tiempos en la gestión de la seguridad, mediante una gestión eficiente de la detección de vulnerabilidades y de la notificación de alertas, así como ofreciendo recomendaciones para un tratamiento oportuno de las mismas.

- Evalúa de forma continua y a tiempo real. Alerta temprana.

- No específica del ENS.

CLARA: Herramienta de auditoría de cumplimiento con el ENS/STIC.

- Evalúa la seguridad en base a plantillas de guías específicas de las series:
  - 500: Entornos Windows
  - 600: Otros entornos (Linux)
  - 800: ENS
- Para ENS y para Sistemas Clasificados.
- Producto instalable:
  - CLARA ENS para entornos Windows: Windows 7, 10, 11, Windows Server 2019, 2022, 2025.
  - CLARA ENS LINUX para entornos Linux (CentOS, RedHat 7 u 8).
- Actualizada en enero de 2025.



Resumen 1/3

Principios
- Responsabilidad activa
- Licitud
- Limitación finalidad
- Minimización
- Exactitud
- Plazo
- Seguridad (I, C)

Roles
- Responsable
- Encargado
- DPD

Deber información
- Responsable
- Finalidad
- Base jurídica
- Destinatarios
- Derechos
- Origen datos

Bases legitimación
- Consentimiento
- Contrato
- Interés vital
- Obligación legal
- Interés o ejercicio público
- Interés legítimo prevalente

Registro Actividades Tratamiento (RAT)

Actividad de Tratamiento	Finalidad	Categorías de Interesados	Categorías datos personales	Cesiones de datos	Transferencias internacionales	Periodo de conservación	Medidas de seguridad

Protección desde el diseño y por defecto
- Minimización (ej. ZNP)
- Seudonimización
- Anonimización
- Cifrado
- Hash

Medidas ENS
- Datos personales
- Criptografía
- Protección confidencialidad

dimensiones	C		
nivel	BAJO	MEDIO	ALTO
	aplica	+ R1	+R1+R2+R3

Resumen 2/3

Gestión riesgos y EIPD

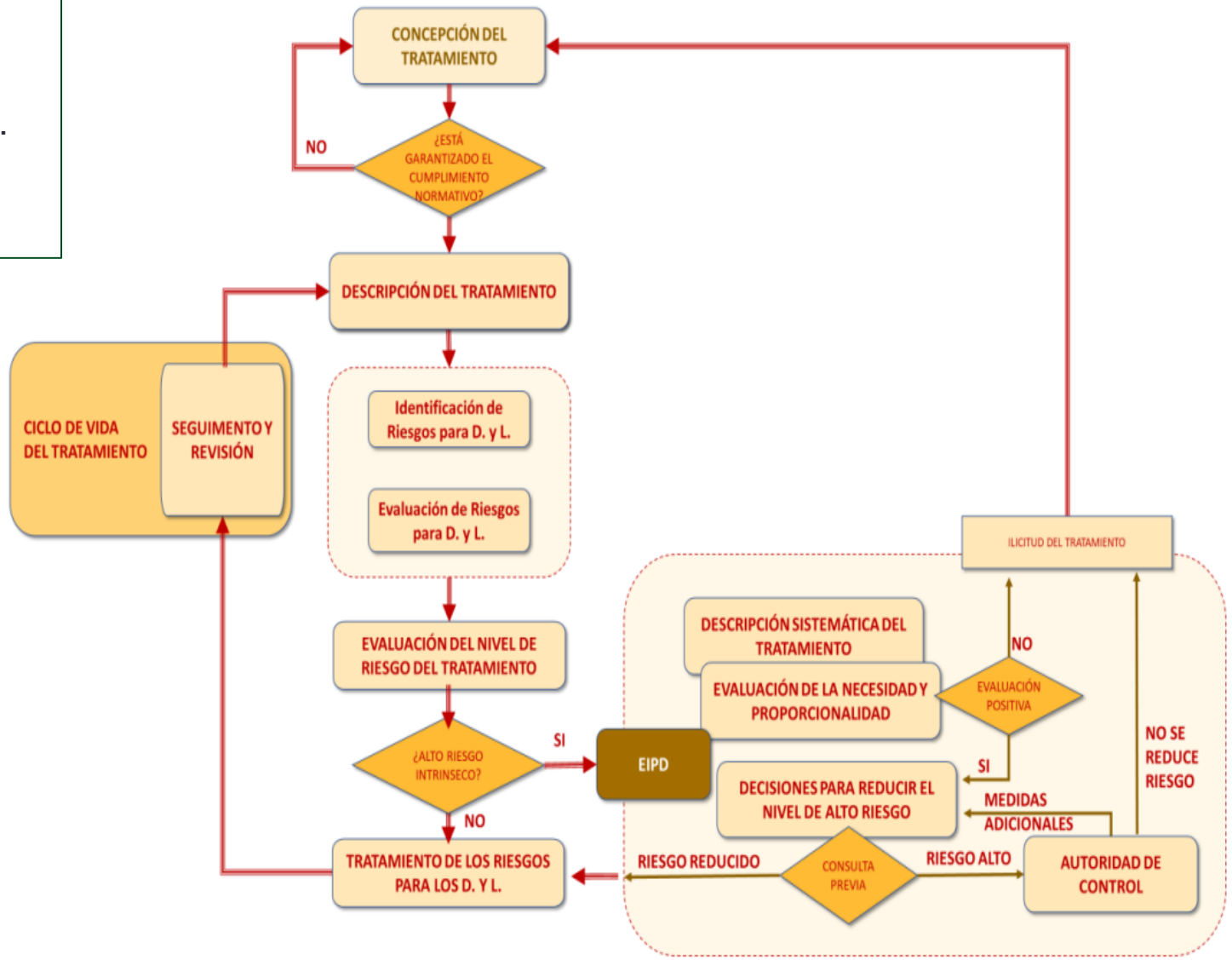
- EIPD si alto riesgo:
  - Evaluación sistemática y exhaustiva (perfiles).
  - Tratamiento gran escala categorías especiales.
  - Observación sistemática a gran escala.
- Listas concretas Sí y No EIPD.

Brechas seguridad

- Notificar AEPD sin dilación (72 horas).
- Comunicar interesados si alto riesgo.

Otros derechos

- Derecho a la portabilidad de los datos.
- Derecho a la supresión (olvido) de los datos.



Resumen 3/3



aepd agencia española protección datos

- Facilita RGPD
- Facilita EMPRENDE
- Evalúa-Riesgo RGPD v2
- Gestiona RGPD
- Canal del DPD
- Asesora Brecha
- Comunica-Brecha
- ValidaCripto

Guías CCN

- CCN-STIC 105. CPSTIC:
  - Cualificados y aprobados.
- CCN-STIC 807. Criptología empleo ENS:
  - Recomendados (R) y heredados (L).
  - Cifrado simétrico AES, 128 o más.
  - Cifrado asimétrico RSA, R>3000.
  - TLS 1.2 o más.
  - SSH v2
  - IPsec (VPNs), modo túnel.

CCN centro criptológico nacional

Producto STIC ens ALTA CCN CUALIFICADO

- inés — Informe del Estado de la Seguridad en el ENS.
- ana — automatización y normalización de auditorías
- amparo — estudio simplificado de sistemas
- clara — Herramienta de auditoría de cumplimiento con el ENS/STIC
- pilar



CEF.-

Gracias por vuestra atención

udima
UNIVERSIDAD A DISTANCIA DE MADRID